



Shri Vaishnav Vidyapeeth Vishwavidyalaya, Indore (MP)

Think Excellence. Live Excellence.

Shri Vaishnav Institute of Information Technology

Department of Information Security & Cloud Computing

Lecture Notes

Network Security and Cryptography

(BTC503N)

Session: July-Dec 2025

Subject Teacher

Dr. Gaurav Shrivastava

B.E. (CSE), M.E. (IT), Ph.D.

Associate Professor (IS & CC Dept.)

SVIIT-SVVV, Indore

Syllabus

UNIT I: Introduction to Network Security: Introduction, Need for Security, Security in Networks: Threats in networks, Network Security Controls – Architecture, Attacks on Computers & Computer Security, Content Integrity, Strong Authentication, Access Controls, Wireless Security, Honey pots.

UNIT II: Security Mechanism: Proxy Servers and Anonymizers, Firewall, Types of firewalls, Password Cracking Techniques. Cryptography: Concepts & Techniques: Introduction, Plaintext & Cipher text, Caesar Cipher, Substitution Techniques, Substitution Boxes (SBoxes), Permutation Cipher, Transposition Techniques, Encryption & Decryption, Symmetric & Asymmetric key Cryptography, Key Length & Key Size.

UNIT III: Symmetric Key Algorithm: Introduction of Block Ciphers, Overview of Symmetric Key Cryptography, DES (Data Encryption Standard) algorithm, Double DES Triple DES, AES, IDEA (International Data Encryption Algorithm) algorithm.

UNIT IV: Asymmetric Key Algorithm: Overview of Asymmetric key Cryptography, RSA algorithm, Symmetric & Asymmetric key Cryptography together, Diffie-Hellman Key Exchange, Digital Signature, Basic concepts of Message Digest and Hash Function. Man in Middle Attack, DoS and DDoS Attacks.

UNIT V: Internet Security Protocols: User Authentication Basic Concepts, SSL protocol, Authentication Basics, Password, Authentication Token, Certificate based Authentication, Biometric Authentication. Steganography its importance. Basics of mail security, Pretty Good Privacy, S/MIME.

UNIT - I

1. Introduction to Network Security:

Network Security protects your network and data from breaches, intrusions and other threats. This is a vast and overarching term that describes hardware and software solutions as well as processes or rules and configurations relating to network use, accessibility, and overall threat protection.

Network Security involves access control, virus and antivirus software, application security, network analytics, types of network-related security (endpoint, web, wireless), firewalls, VPN encryption and more.

2. Need for Security

Companies have realized the need and importance of information security and taken steps to be included among organizations known to have the most secure IT infrastructure. As a result, enormous capital is spent every year from companies' budgets to protect the critical information that forms the foundation of their business. Below are a few reasons why information security is critical to the success of any organization.

➤ To prevent data breaches

A data breach resulting in the loss of critical business information is quite common. Due to a large amount of data stored on company servers, businesses often become the main target of cyber-criminals if the network is unprotected. The breaches involving business secrets, confidential health information, and intellectual property can greatly impact the overall health of a business.

➤ To check for compromised credentials and broken authentication

Data breaches and other cyber-attacks are usually a result of lax authentication, weak passwords, and poor certificate or key management. Companies often struggle with assigning permissions to appropriate users or departments, resulting in identity theft.

➤ To avoid account hijacking

Phishing, fraud, and software exploitations are still very common. Companies relying on cloud services are especially at risk because they are an easy target for cybercriminals, who can eavesdrop on activities, modify data and manipulate transactions. These third-party applications can be used by attackers to launch other attacks as well.

➤ To mitigate cyber threats from malicious insiders

An existing or former employee, a cunning business partner, a system administrator or an intruder can destroy the whole information infrastructure or manipulate data for their own

purpose. Therefore, it is the responsibility of an organization to take effective measures to control the encryption process and keys. Effective monitoring, logging, and auditing activities are extremely important to keep everything under control.

3. Types of Information Security Controls

There are three different types of information security controls used to protect data.

- **Physical Control:** Physical controls are the simplest form of information security. These are the things that can actually be touch and seen, such as password-protected locks to avoid unauthorized entry to a secure server room, alarm systems, fences and more.
- **Administrative Control:** These controls mainly involve manual efforts to ensure data security. These include enforcing policies, standards, guidelines and following procedures to ensure business continuity and data protection. Some of the examples of administrative controls include disaster recovery plans, internet usage policies and termination procedures.
- **Technical Control:** These controls are considered the most effective of all because they make use of the latest technologies and systems to limit access to information. Some of the examples of technical controls include firewalls, anti-virus software, file permissions, access control lists and cutting-edge data security technologies that are hard to penetrate.

4. Threats in networks

A network security threat is exactly that: a threat to your network and data systems. Any attempt to breach your network and obtain access to your data is a network threat.

There are different kinds of network threats, and each has different goals. Some, like distributed denial-of-service (DDoS) attacks, seek to shut down your network or servers by overwhelming it with requests. Other threats, like malware or credential theft, are aimed at stealing your data. Still others, like spyware, will insert themselves into your organization's network, where they'll lie in wait, collecting information about your organization.

There are four main kinds of network threats:

- a) **External threats:** Threats made by outside organizations or individuals, attempting to get into your network.
- b) **Internal threats:** These are threats from malicious insiders, such as disgruntled or improperly vetted employees who are working for someone else. These are common. According to Forrester, 46% of breaches in 2019 involved insiders like employees and third-party partners.
- c) **Structured threats:** Organized attacks by attackers who know what they're doing and have a clear aim or goal in mind. State-sponsored attacks, for example, fall into this category.

- d) **Unstructured attacks:** Disorganized attacks, often by amateurs with no concrete goal in mind.

5. Attacks on Computers

What is a Security attack?

Security attacks jeopardize the system's security. These are the unauthorized or illegal actions that are taken against the government, corporate, or private IT assets in order to destroy, modify, or steal the sensitive data. They are further classified into active and passive attacks, in which the attacker gets unlawful access to the system's resources.

Active attacks

In active attacks, the attacker intercepts the connection and efforts to modify the message's content. It is dangerous for integrity and availability of the message. Active attacks involve Masquerade, Modification of message, Repudiation, Replay, and Denial of service. The system resources can be changed due to active attacks. So, the damage done with active attacks can be harmful to the system and its resources.

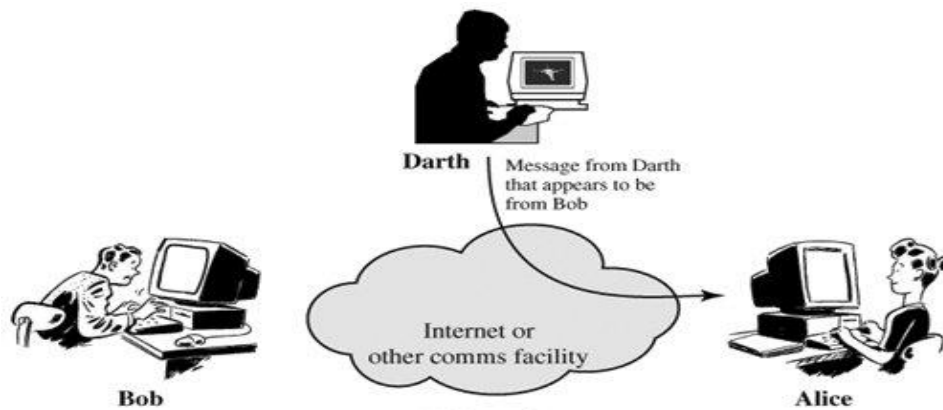
In active attacks, the victim gets notified about the attack. The implication of an active attack is typically difficult and requires more effort. Active attacks can be prevented by using some techniques. We can try the below-listed measures to prevent these attacks -

- Use of one-time password help in the authentication of the transactions between two parties.
- There could be a generation of the random session key that will be valid for a single transaction. It should prevent the malicious user from retransmitting the actual information once the session ends.

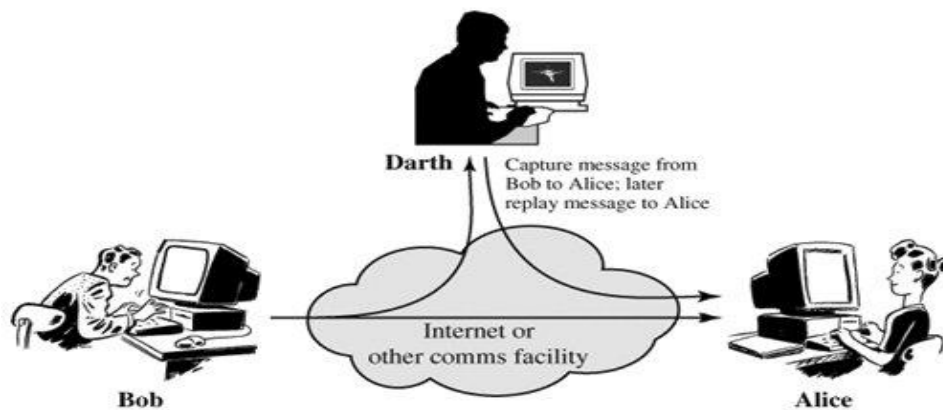
These attacks involve some modification of the data stream or the creation of a false stream. These attacks can be classified in to four categories:

- **Masquerade** – One entity pretends to be a different entity.
- **Replay** – involves passive capture of a data unit and its subsequent transmission to produce an unauthorized effect.
- **Modification of messages** – Some portion of message is altered or the messages are delayed or recorded, to produce an unauthorized effect.
- **Denial of service** – Prevents or inhibits the normal use or management of communication facilities. Another form of service denial is the disruption of an entire network, either by disabling the network or overloading it with messages so as to degrade performance.

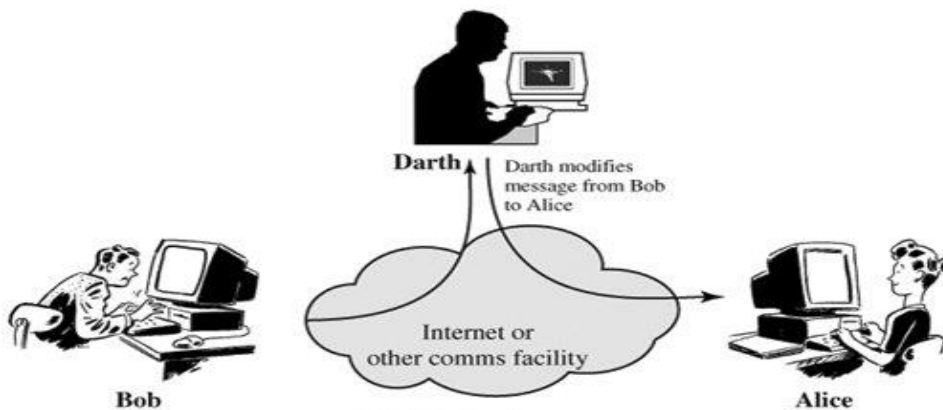
It is quite difficult to prevent active attacks absolutely, because to do so would require physical protection of all communication facilities and paths at all times. Instead, the goal is to detect them and to recover from any disruption or delays caused by them.



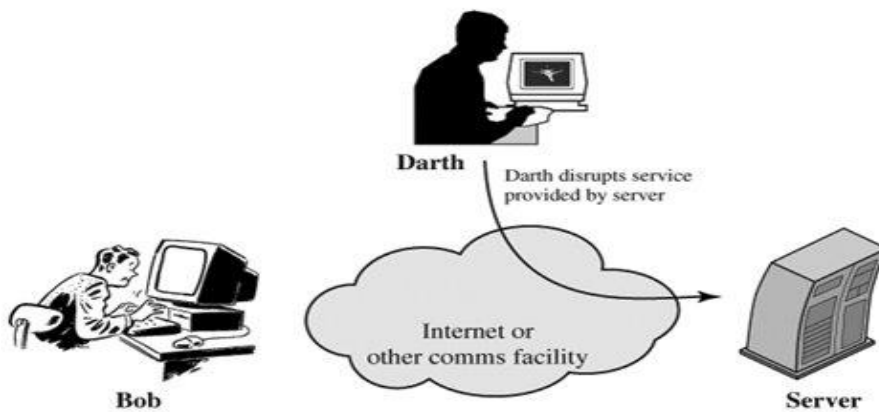
(a) Masquerade



(b) Replay



(c) Modification of messages

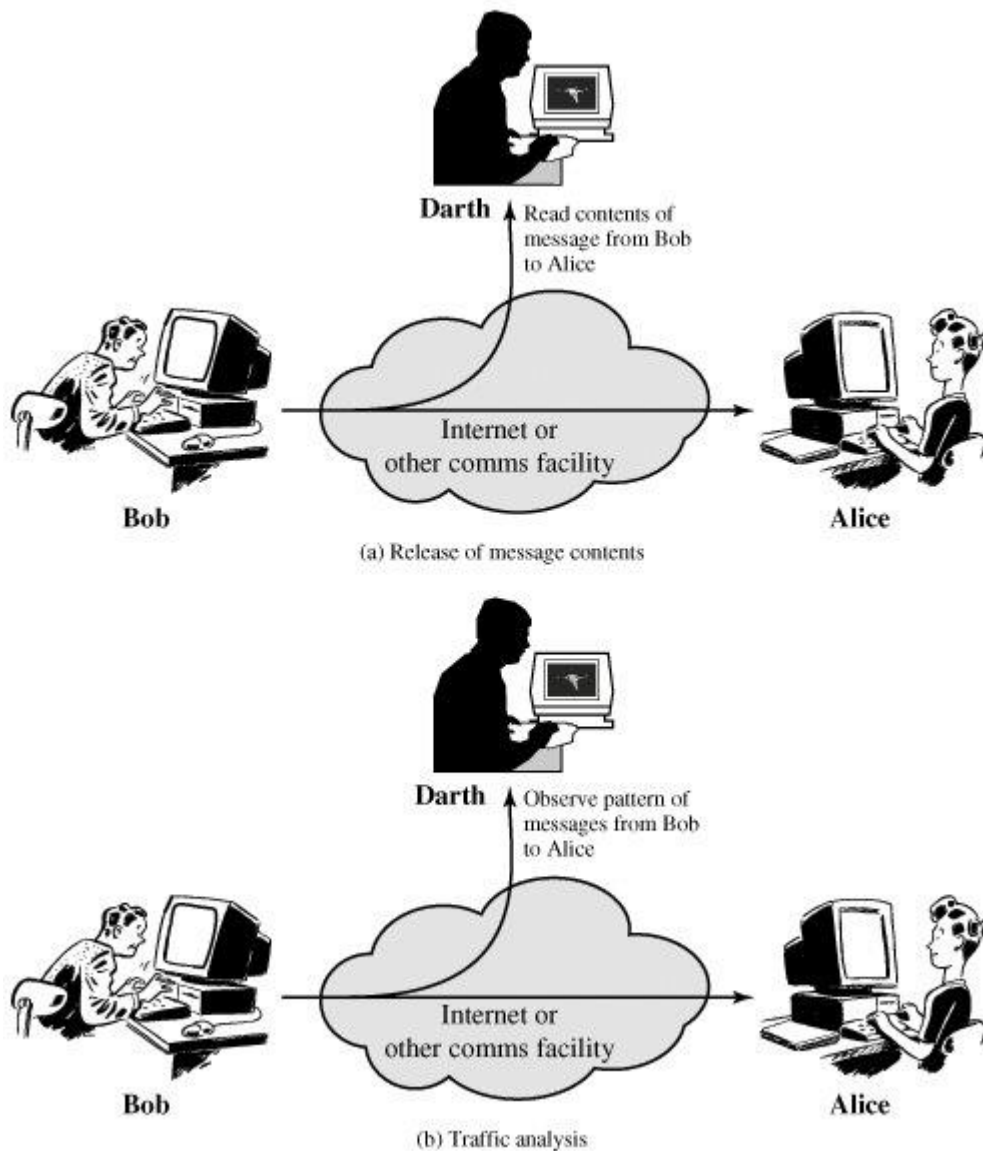


(d) Denial of service

Passive attacks

In passive attacks, the attacker observes the messages, then copy and save them and can use it for malicious purposes. The attacker does not try to change the information or content he/she gathered. Although passive attacks do not harm the system, they can be a danger for the confidentiality of the message.

In the below image, we can see the process of passive attacks.



Unlike active attacks, in passive attacks, victims do not get informed about the attack. It is difficult to detect as there is no alteration in the message. Passive attacks can be prevented by using some encryption techniques. We can try the below-listed measures to prevent these attacks -

- We should avoid posting sensitive information or personal information online. Attackers can use this information to hack your network.
- We should use the encryption method for the messages and make the messages unreadable for any unintended intruder.

Passive attacks are in the nature of eavesdropping on, or monitoring of, transmissions. The goal of the opponent is to obtain information that is being transmitted. Passive attacks are of two types:

- **Release of message contents:** A telephone conversation, an e-mail message and a transferred file may contain sensitive or confidential information. We would like to prevent the opponent from learning the contents of these transmissions.
- **Traffic analysis:** If we had encryption protection in place, an opponent might still be able to observe the pattern of the message. The opponent could determine the location and identity of communication hosts and could observe the frequency and length of messages being exchanged. This information might be useful in guessing the nature of communication that was taking place.

Passive attacks are very difficult to detect because they do not involve any alteration of data. However, it is feasible to prevent the success of these attacks.

Active Attack v/s Passive Attack

Now, let's see the comparison chart between Active attack and Passive attack. We are comparing both security attacks on the basis of some characteristics.

On the basis of	Active attack	Passive attack
Definition	In active attacks, the attacker intercepts the connection and efforts to modify the message's content.	In passive attacks, the attacker observes the messages, then copy and save them and can use it for malicious purposes.
Modification	In an active attack, the attacker modifies the actual information.	In passive attacks, information remains unchanged.
Victim	In active attacks, the victim gets notified about the attack.	Unlike active attacks, in passive attacks, victims do not get informed about the attack.
System's impact	The damage done with active attacks can be harmful to the system and its resources.	The passive attacks do not harm the system.
System resources	In active attacks, the system resources can be changed.	In passive attacks, the system resources remain unchanged.
Dangerous for	They are dangerous for the integrity and availability of the message.	They can be dangerous for confidentiality of the message.
Emphasis on	In active attacks, attention is on detection.	In active attacks, attention is on prevention.
Types	Active attacks involve Masquerade, Modification of message, Repudiation, Replay, and Denial of	It involves traffic analysis, the release of a message.

	service.	
Prevention	Active attacks are tough to restrict from entering systems or networks.	Unlike active attacks, passive attacks are easy to prohibit.

6. Different Types of Attacks

6.1 Malware

The term “malware” encompasses various types of attacks including spyware, viruses, and worms. Malware uses a vulnerability to breach a network when a user clicks a “planted” dangerous link or email attachment, which is used to install malicious software inside the system.

Malware and malicious files inside a computer system can:

- Deny access to the critical components of the network
- Obtain information by retrieving data from the hard drive
- Disrupt the system or even render it inoperable

Malware is so common that there is a large variety of modus operandi. The most common types being:

- **Viruses**—A virus is a malicious executable code attached to another executable file that can be harmless or can modify or delete data. When the computer program runs attached with a virus it performs some action such as deleting a file from the computer system. Viruses can’t be controlled by remote. The ILOVEYOU virus spreads through email attachments.
- **Trojans**—A program hiding inside a useful program with malicious purposes. Unlike viruses, a trojan doesn’t replicate itself and it is commonly used to establish a backdoor to be exploited by attackers.
- **Worms**—Worms are similar to a virus but it does not modify the program. It replicates itself more and more to cause slow down the computer system. Worms can be controlled by remote. The main objective of worms is to eat the system resources. The WannaCry ransomware worm in 2000 exploits the Windows Server Message Block (SMBv1) which is a resource-sharing protocol.
- **Ransomware**—A type of malware that denies access to the victim data, threatening to publish or delete it unless a ransom is paid. Advanced ransomware uses cryptoviral extortion, encrypting the victim’s data so that it is impossible to decrypt without the decryption key.
- **Spyware**—A type of program installed to collect information about users, their systems or browsing habits, sending the data to a remote user. The attacker can then use the information for blackmailing purposes or download and install other malicious programs from the web.

6.2 Phishing

Phishing attacks are extremely common and involve sending mass amounts of fraudulent emails to unsuspecting users, disguised as coming from a reliable source. The fraudulent emails often have the appearance of being legitimate, but link the recipient to a malicious file or script designed to grant attackers access to your device to control it or gather recon, install malicious scripts/files, or to extract data such as user information, financial info, and more.

Phishing attacks can also take place via social networks and other online communities, via direct messages from other users with a hidden intent. Phishers often leverage social engineering and other public information sources to collect info about your work, interests, and activities—giving attackers an edge in convincing you they're not who they say.

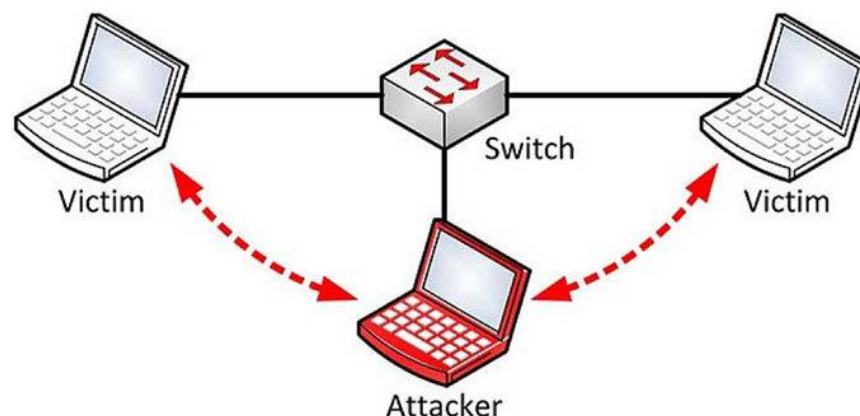
There are several different types of phishing attacks, including:

- **Spear Phishing**—targeted attacks directed at specific companies and/or individuals.
- **Whaling**—attacks targeting senior executives and stakeholders within an organization.
- **Pharming**—leverages DNS cache poisoning to capture user credentials through a fake login landing page.

Phishing attacks can also take place via phone call (voice phishing) and via text message (SMS phishing).

6.3 Man-in-the-Middle (MitM) Attacks

Occurs when an attacker intercepts a two-party transaction, inserting themselves in the middle. From there, cyber attackers can steal and manipulate data by interrupting traffic.



This type of attack usually exploits security vulnerabilities in a network, such as an unsecured public WiFi, to insert themselves between a visitor's device and the network. The problem with this kind of attack is that it is very difficult to detect, as the victim thinks the information is going to a legitimate destination. Phishing or malware attacks are often leveraged to carry out a MitM attack.

6.4 Denial-of-Service (DOS) Attack

DoS attacks work by flooding systems, servers, and/or networks with traffic to overload resources and bandwidth. The result is rendering the system unable to process and fulfill legitimate requests. In addition to denial-of-service (DoS) attacks, there are also distributed denial-of-service (DDoS) attacks.

DoS attacks saturate a system's resources with the goal of impeding response to service requests. On the other hand, a DDoS attack is launched from several infected host machines with the goal of achieving service denial and taking a system offline, thus paving the way for another attack to enter the network/environment.

The most common types of DoS and DDoS attacks are the TCP SYN flood attack, teardrop attack, smurf attack, ping-of-death attack, and botnets.

6.5 SQL Injections

This occurs when an attacker inserts malicious code into a server using server query language (SQL) forcing the server to deliver protected information. This type of attack usually involves submitting malicious code into an unprotected website comment or search box. Secure coding practices such as using prepared statements with parameterized queries is an effective way to prevent SQL injections.

When a SQL command uses a parameter instead of inserting the values directly, it can allow the backend to run malicious queries. Moreover, the SQL interpreter uses the parameter only as data, without executing it as a code. Learn more about how secure coding practices can prevent SQL injection [here](#).

6.6 Password Attack

Passwords are the most widespread method of authenticating access to a secure information system, making them an attractive target for cyber attackers. By accessing a person's password, an attacker can gain entry to confidential or critical data and systems, including the ability to manipulate and control said data/systems.

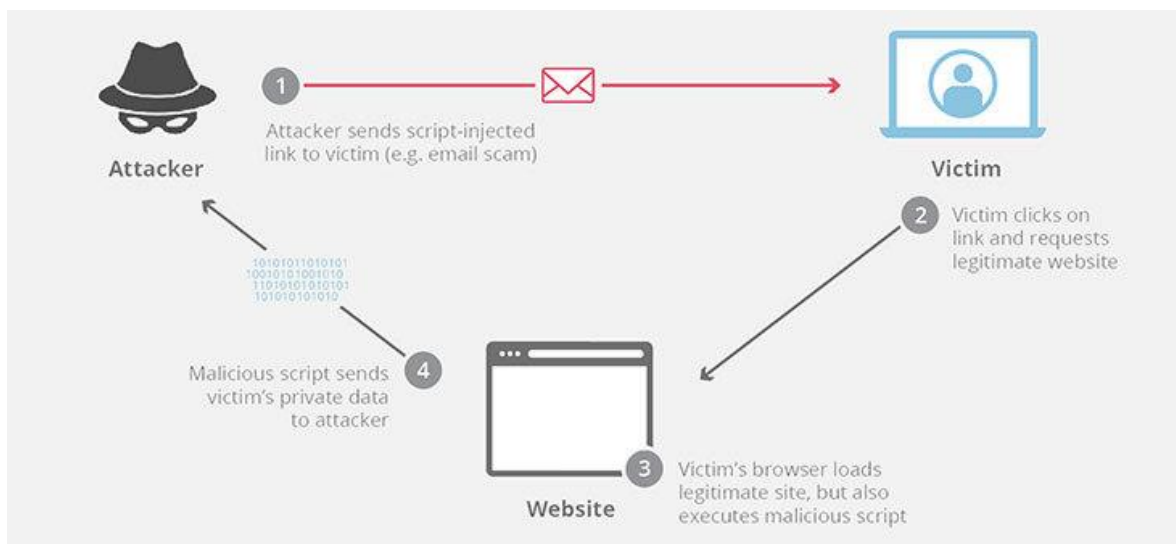
Password attackers use a myriad of methods to identify an individual password, including using social engineering, gaining access to a password database, testing the network connection to obtain unencrypted passwords, or simply by guessing.

The last method mentioned is executed in a systematic manner known as a “brute-force attack.” A brute-force attack employs a program to try all the possible variants and combinations of information to guess the password.

Another common method is the dictionary attack, when the attacker uses a list of common passwords to attempt to gain access to a user’s computer and network. Account lockout best practices and two-factor authentication are very useful at preventing a password attack. Account lockout features can freeze the account out after a number of invalid password attempts and two-factor authentication adds an additional layer of security, requiring the user logging in to enter a secondary code only available on their 2FA device(s).

6.7 Cross-site Scripting

A cross-site scripting attack sends malicious scripts into content from reliable websites. The malicious code joins the dynamic content that is sent to the victim’s browser. Usually, this malicious code consists of Javascript code executed by the victim’s browser, but can include Flash, HTML, and XSS.



Additional information about cross-site scripting attacks can be found [here](#).

6.8 Rootkits

Rootkits are installed inside legitimate software, where they can gain remote control and administration-level access over a system. The attacker then uses the rootkit to steal passwords, keys, credentials, and retrieve critical data.

Since rootkits hide in legitimate software, once you allow the program to make changes in your OS, the rootkit installs itself in the system (host, computer, server, etc.) and remains dormant until the attacker activates it or it’s triggered through a persistence mechanism. Rootkits are commonly spread through email attachments and downloads from insecure websites.

6.9 Internet of Things (IoT) Attacks

While internet connectivity across almost every imaginable device creates convenience and ease for individuals, it also presents a growing—almost unlimited—number of access points for attackers to exploit and wreak havoc. The interconnectedness of things makes it possible for attackers to breach an entry point and use it as a gate to exploit other devices in the network.

IoT attacks are becoming more popular due to the rapid growth of IoT devices and (in general) low priority given to embedded security in these devices and their operating systems. In one IoT attack case, a Vegas casino was attacked and the hacker gained entry via an internet-connected thermometer inside one of the casino's fishtanks.

Best practices to help prevent an IoT attack include updating the OS and keeping a strong password for every IoT device on your network, and changing passwords often.

7. Content Integrity

Integrity is the protection of system data from intentional or accidental unauthorized changes. The challenges of the security program are to ensure that data is maintained in the state that is expected by the users. Although the security program cannot improve the accuracy of the data that is put into the system by users. It can help ensure that any changes are intended and correctly applied. An additional element of integrity is the need to protect the process or program used to manipulate the data from unauthorized modification. A critical requirement of both commercial and government data processing is to ensure the integrity of data to prevent fraud and errors. It is imperative; therefore, no user be able to modify data in a way that might corrupt or lose assets or financial records or render decision making information unreliable. Examples of government systems in which integrity is crucial include air traffic control system, military fire control systems, social security and welfare systems. Examples of commercial systems that require a high level of integrity include medical prescription system, credit reporting systems, production control systems and payroll systems.

Protecting against Threats to Integrity: Like confidentiality, integrity can also be arbitrated by hackers, masqueraders, unprotected downloaded files, LANs, unauthorized user activities, and unauthorized programs like Trojan Horse and viruses, because each of these threads can lead to unauthorized changes to data or programs. For example, unauthorized user can corrupt or change data and programs intentionally or accidentally if their activities on the system are not properly controlled. Generally, three basic principles are used to establish integrity controls:

1. **Need-to-know access:** User should be granted access only on to those files and programs that they need in order to perform their assigned jobs functions.
2. **Separation of duties:** To ensure that no single employee has control of a transaction from beginning to end, two or more people should be responsible for performing it.

3. **Rotation of duties:** Job assignment should be changed periodically so that it becomes more difficult for the users to collaborate to exercise complete control of a transaction and subvert it for fraudulent purposes.

Integrity Models – Integrity models are used to describe what needs to be done to enforce the information integrity policy. There are three goals of integrity, which the models address in various ways:

1. Preventing unauthorized users from making modifications to data or programs.
2. Preventing authorized users from making improper or unauthorized modifications.
3. Maintaining internal and external consistency of data and programs.

8. Strong Authentication:

The username/password combination has been the standard authentication mechanism for decades. Strong authentication techniques build on that foundation.

Strong authentication techniques combine two independent factors to confirm someone's identity and access. Compromising one leaves the other intact, so systems stay safe. And one element isn't ever reused, so it's nearly impossible to steal.

Consider this simplified strong authentication process using an SMS One-time Passcode (OTP):

- **Step 1: Password:** The person creates and memorizes a unique set of numbers and letters used to access the system.
- **Step 2: Possession:** After typing in the correct password, a secondary string of letters and numbers is sent to the user's registered smartphone.
- **Step 3: Access:** After tapping in the second set of details, the user can get into the system.

Logging on via this method takes time and a few extra steps. But we live in a world where apps contain confidential, personally identifiable information we must protect.

Passwords alone are not enough, as the only security measure standing in the way of total compromise is a string of input characters. Today's security threats require much more robust protection measures.

The Role of Risk Explained

Some companies use strong authentication techniques to verify every login request. Others use a risk-based authentication method to verify only those requests that seem somehow suspect.

During a login request, the system assesses:

- **Locations.** Where is the request coming from?
- **Timestamps.** When is the user requesting a login?
- **Frequency.** How often has the user tried to log in previously?

Clear risks may emerge. For example, a company may notice multiple login requests from a foreign country during an unusual time of day. Or the system may recognize a routine request from someone who always logs in from that location at the same time.

If a risk is detected, the system can deploy enhanced authentication techniques, such as new passwords or biometric verifications. If no hazard is detected, the user logs on without extra required steps.

Is Strength Worthwhile?

You may believe that your data is already protected and that your company already takes reasonable steps to prevent unauthorized access. In reality, very real data protection problems lurk in almost every environment. And sometimes, companies are required to demonstrate that they are using strong authentication techniques.

The FIDO Alliance advocates for universal strong authentication techniques, and the group uses these startling statistics to prompt compliance:

- Password issues spark more than 80 percent of data breaches.
- Up to 51 percent of passwords aren't original.

A data breach can result in lost revenue, and you may also lose the trust and respect of your customer base. When your customers aren't certain you will respect their work and privacy, they may choose to work with your competition instead.

If you work in the financial sector, or you accept payments from people in the European Union, strong authentication isn't optional for you. The strong customer authentication (SCA) rules went into effect in 2019, and they require strong verifications for in-app payments in the European Economic Area (EEA).

Types of Strong Authentication

You have plenty of options to choose from. However, not all factors are created equal. Different factors have varying degrees of assurance and practical usability.

Here are common types of second factors:

- a) **Security questions:** Security questions have traditionally been used for password resets, but there is nothing stopping you from adding security questions as an additional authentication factor.

They're simple to set up, but they can be hacked or stolen very easily.

- b) **One-time passwords (OTPs):** OTPs are more secure than security questions as they use a secondary authentication category. The user has a device (something they have) over and above their password (something they know).

Verification codes or OTPs sent via SMS are also convenient, but there are risks to using traditional OTPs as tokens have been intercepted and compromised.

- c) **App-generated codes:** A software-based OTP uses the time-based one-time password algorithm (TOTP) presented via a third-party app.

App-generated OTPs are built with security in mind. But potential smartphone penetration is a drawback.

- d) **Specialized authentication apps:** Rather than providing the user with an OTP, this requires users to verify their identity by interacting with the app on their smartphone, such as Okta's Verify by Push app.

The authentication token is then sent to the service directly, strengthening security by eliminating the need for a user-entered OTP.

- e) **Physical authentication keys:** The authentication process is secured by an asymmetric encryption algorithm where the private key never leaves the device. USBs that are plugged in when prompted and smart cards that users swipe are examples.

U2F is a standard maintained by the FIDO Alliance and is supported by Chrome, Firefox, and Opera.

- f) **Biometrics:** Authentication is reinforced by something you are over and above something you know and something you have. This is tough to hack, but no method is perfect, and biometrics come with challenges and privacy concerns.

Like passwords, biometric data must be stored in some form of database, which could be compromised. And unlike a password, you cannot change your fingerprint, iris, or retina once this happens. Furthermore, implementing this MFA factor requires investment in specialized biometric hardware devices.

- g) **Cryptographic challenge response protocol:** A database sends a challenge to another, and the recipient must respond with the appropriate answer. All the communication is encrypted during transmission, so it can't be hacked or manipulated. These systems sound complex, but in reality, the sender and the recipient finish the communication in seconds.

9. Access control

Access control is a method of limiting access to a system or to physical or virtual resources. It is a process by which users can access and are granted certain prerogative to systems, resources or information. Access control is a security technique that has control over who can view different aspects, what can be viewed and who can use resources in a computing environment. It is a fundamental concept in security that reduces risk to the business or organization.

To establish a secure system, electronic access control systems are used that depend on user credentials, access card readers, auditing and reports to track employee access to restricted business locations and areas. These systems include access control panels to prohibit entry to sensitive areas like alarms and lock down areas to prevent unauthorized access or operations.

Access control systems perform identification, authentication, and authorization of users and entities by evaluating required login credentials that may include passwords, pins, bio-metric scans or other authentication factors. There is multi-factor authentication which requires two or more authentication factors which is often an important part of the layered defense to protect access control systems.

Authentication Factors:

- Password or PIN
- Bio-metric measurement (fingerprint & retina scan)
- Card or Key

Different access control models are used depending on the compliance requirements and the security levels of information technology that is to be protected. Basically access control is of 2 types:

1. **Physical Access Control:** Physical access control restricts entry to campuses, buildings, rooms and physical IT assets.
2. **Logical Access Control:** Logical access control limits connections to computer networks, system files and data.

Access Control Models:

1. **Attribute-based Access Control (ABAC):** In this model, access is granted or declined by evaluating a set of rules, policies, and relationships using the attributes of users, systems and environmental conditions.
2. **Discretionary Access Control (DAC):** In DAC, the owner of data determines who can access specific resources.
3. **History-Based Access Control (HBAC):** Access is granted or declined by evaluating the history of activities of the inquiring party that includes behavior, the time between requests and content of requests.
4. **Identity-Based Access Control (IBAC):** By using this model network administrators can more effectively manage activity and access based on individual requirements.
5. **Mandatory Access Control (MAC):** A control model in which access rights are regulated by a central authority based on multiple levels of security. Security Enhanced Linux is implemented using MAC on the Linux operating system.

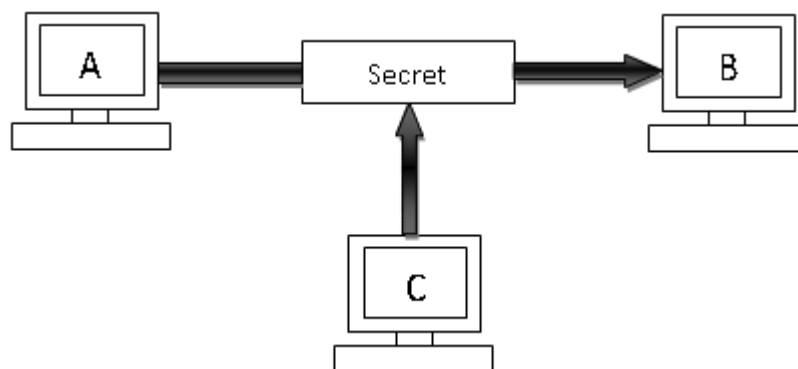
6. **Organization-Based Access control (OrBAC):** This model allows the policy designer to define a security policy independently of the implementation.
7. **Role-Based Access Control (RBAC):** RBAC allows access based on the job title. RBAC eliminates discretion on a large scale when providing access to objects. For example, there should not be permissions for human resources specialist to create network accounts.
8. **Rule-Based Access Control (RAC):** RAC method is largely context based. Example of this would be only allowing students to use the labs during a certain time of day.

10. Principles of Security:

a) Confidentiality:

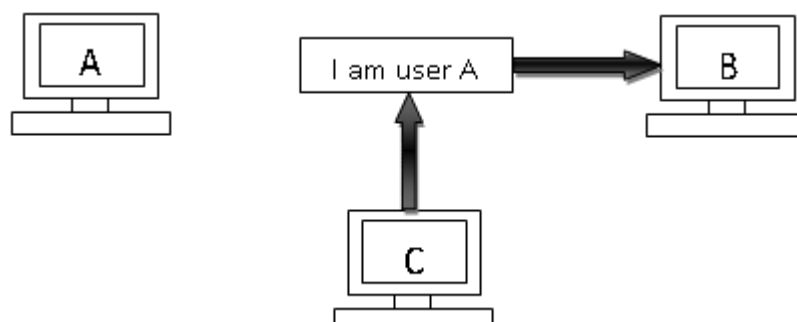
The degree of confidentiality determines the secrecy of the information. The principle specifies that only the sender and receiver will be able to access the information shared between them. Confidentiality compromises if an unauthorized person is able to access a message.

For example, let us consider sender A wants to share some confidential information with receiver B and the information gets intercepted by the attacker C. Now the confidential information is in the hands of an intruder C.



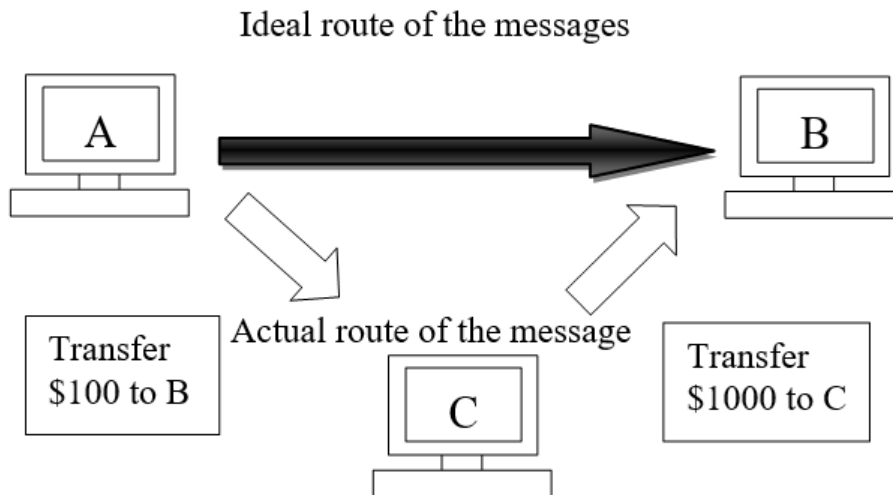
b) Authentication:

Authentication is the mechanism to identify the user or system or the entity. It ensures the identity of the person trying to access the information. The authentication is mostly secured by using username and password. The authorized person whose identity is preregistered can prove his/her identity and can access the sensitive information.



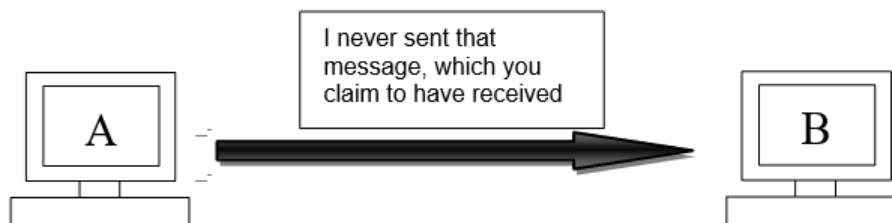
c) **Integrity:**

Integrity gives the assurance that the information received is exact and accurate. If the content of the message is changed after the sender sends it but before reaching the intended receiver, then it is said that the integrity of the message is lost.



d) **Non-Repudiation:**

Non-repudiation is a mechanism that prevents the denial of the message content sent through a network. In some cases the sender sends the message and later denies it. But the non-repudiation does not allow the sender to refuse the receiver.



e) **Access control:**

The principle of access control is determined by role management and rule management. Role management determines who should access the data while rule management determines up to what extent one can access the data. The information displayed is dependent on the person who is accessing it.

f) **Availability:**

The principle of availability states that the resources will be available to authorize party at all times. Information will not be useful if it is not available to be accessed. Systems should have sufficient availability of information to satisfy the user request.

g) Issues of ethics and law

The following categories are used to categorize ethical dilemmas in the security system.

- Individuals: right to access personal information is referred to as privacy.
- Property: It is concerned with the information's owner.
- Accessibility: is concerned with an organization's right to collect information.
- Accuracy: It is concerned with the obligation of information authenticity, fidelity, and accuracy.

11. Wireless Security

Wireless security is in essence, the prevention of unwanted users from accessing a particular wireless network. More so, wireless security, also known as Wi-Fi security, aims to ensure that your data remains only accessible to users you authorize.

How Does Wireless Security Work?

Wireless Security Protocols such as Wired Equivalent Privacy (WEP) and Wi-Fi Protected Access (WPA) is the authentication security protocols created by the Wireless Alliance used to ensure wireless security. There are four wireless security protocols currently available.

- Wired Equivalent Privacy (WEP)
- Wi-Fi Protected Access (WPA)
- Wi-Fi Protected Access 2 (WPA 2)
- Wi-Fi Protected Access 3 (WPA 3)

To be sure your network is secure, you must first identify which network yours falls under.

What Are the Types of Wireless Security?

As previously mentioned, there are four main types of wireless security protocols. Each of these varies in utility and strength.

a) WIRED EQUIVALENT PRIVACY (WEP)

Wired Equivalent Privacy (WEP) is the first security protocol ever put in practice. Designed in 1997, it has become obsolete but is still used in modern times with older devices.

WEP uses a data encryption scheme that is based on a combination of user- and system-generated key values. However, it is widely known that WEP is the least secure network

type as hackers have developed tactics of reverse-engineering and cracking the encryption system.

b) WI-FI PROTECTED ACCESS (WPA)

Wi-Fi Protected Access (WPA) was developed to deal with the flaws that were found with the WEP protocol. WPA offers features such as the Temporal Key Integrity Protocol (TKIP) which was a dynamic 128-bit key that was harder to break into than WEP's static, unchanging key.

It also introduced the Message Integrity Check, which scanned for any altered packets sent by hackers, the Temporal Key Integrity Protocol (TKIP), and the pre-shared key (PSK), among others, for encryption.

c) WI-FI PROTECTED ACCESS 2 (WPA2)

In 2004, WPA2 brought significant changes and more features to the wireless security gambit. WPA2 replaced TKIP with the Counter Mode Cipher Block Chaining Message Authentication Code Protocol (CCMP) which is a far superior encryption tool.

WPA2 has been the industry standard since its inception, on March 13, 2006, the Wi-Fi Alliance stated that all future devices with the Wi-Fi trademark had to use WPA2.

- **WPA2-PSK**

WPA2-PSK (Pre-Shared Key) requires a single password to get on the wireless network. It's generally accepted that a single password to access Wi-Fi is safe but only as much as you trust those using it. A major vulnerability comes from the potential damage done when login credentials get placed in the wrong hands. That is why this protocol is most often used for a residential or open Wi-Fi network.

To encrypt a network with WPA2-PSK you provide your router not with an encryption key, but rather with a plain-English passphrase between 8 and 63 characters long. Using CCMP, that passphrase, along with the network SSID, is used to generate unique encryption keys for each wireless client. And those encryption keys are constantly changed. Although WEP also supports passphrases, it does so only as a way to more easily create static keys, which are usually composed of the hex characters 0-9 and A-F.

- **WPA2-Enterprise**

WPA2-Enterprise requires a RADIUS server, which handles the task of authenticating network user's access. The actual authentication process is based on the 802.1X policy and comes in several different systems labeled EAP.

There are just a few components that are needed to make WPA2-Enterprise work. Realistically, if you already have access points and some spare server space, you possess all the hardware needed to make it happen.

Because each device is authenticated before it connects, a personal, encrypted tunnel is effectively created between the device and the network. The security benefits of a properly configured WPA2-Enterprise grant a near-impenetrable network. This protocol is most often used by businesses and governments due to its heightened security measures.

SecureW2 is an industry leader in WPA2-Enterprise security solutions – everything from certificate-based authentication to device onboarding. See how we can strengthen your network security today.

d) WI-FI PROTECTED ACCESS 3 (WPA3)

WPA3 is introducing the first major changes to wireless security in 14 years. Some notable additions for the security protocol are:

Greater protection for passwords

Individualized encryption for personal and open networks

More security for enterprise networks.

WPA3-PSK

To improve the effectiveness of PSK updates to WPA3-PSK offer greater protection by improving the authentication process.

A strategy to do this uses Simultaneous Authentication of Equals (SAE) to make brute-force dictionary attacks far more difficult for a hacker. This protocol requires interaction from the user on each authentication attempt, causing a significant slowdown for those attempting to brute-force through the authentication process.

WPA3-Enterprise

WPA3-Enterprise offers some added benefits but overall little changes in terms of security with the jump from WPA2-Enterprise.

A significant improvement that WPA3-Enterprise offers is a requirement for server certificate validation to be configured to confirm the identity of the server to which the device is connecting. However, due to the lack of major improvements, it's not likely to be a quick transition to WPA3. WPA2 became a standard in 2004, and even today organizations have a difficult time supporting it on their network. That's why we came up with a solution that provides everything you need for 802.1x.

What are the Main Threats to Wi-Fi Security?

As the internet is becoming more accessible, via mobile devices and gadgets, data security is becoming a top concern from the public, as it should be. Data breaches and security malfunctions can cost individuals and businesses thousands of dollars.

It is important to know the threats that are most prevalent in order to be able to implement the proper security measures.

MAN-IN-THE-MIDDLE ATTACKS

A man-in-the-middle (MITM) attack is an incredibly dangerous type of cyber attack that involves a hacker infiltrating a private network by impersonating a rogue access point and acquiring login credentials.

The attacker sets up hardware pretending to be a trusted network, namely Wi-Fi, in order to trick unsuspecting victims into connecting to it and sending over their credentials. MITM attacks can happen anywhere, as devices connect to the network with the strongest signal, and will connect to any SSID name they remember.

Interested in learning more about MITM attacks, read another one of our articles [here](#).

CRACKING AND DECRYPTING PASSWORDS

Cracking and decrypting passwords is an old method that consists of what is known as “A brute force attack.” This attack consists of using a trial-and-error approach and hoping to eventually guess correctly. However, there are many tools that hackers can use to expedite the process.

Luckily, you can use these same tools to try and test your own network’s security. Software like John the Ripper, Nessus, and Hydra are a good place to start.

PACKET SNIFFERS

Packet sniffers are computer programs that can monitor traffic on a wireless network. They can also intercept some data packages and provide a user with their contents. They can be used to harmlessly gather data about traffic, but in the wrong hands can introduce errors and break down a network.

Honeypots:

Honeypot is a network-attached system used as a **trap for cyber-attackers** to detect and study the tricks and types of attacks used by hackers. It acts as a potential target on the internet and informs the defenders about any unauthorized attempt to the information system.

Honeypots are mostly used by large companies and organizations involved in cybersecurity. It helps cybersecurity researchers to learn about the different type of attacks used by attackers. It is suspected that even the cybercriminals use these honeypots to decoy researchers and spread wrong information.

The cost of a honeypot is generally high because it requires specialized skills and resources to implement a system such that it appears to provide an organization's resources still preventing attacks at the backend and access to any production system.

A **honeynet** is a combination of two or more honeypots on a network.

Types of Honeypots:

Honeypots are classified based on their deployment and the involvement of the intruder. Based on their deployment, honeypots are divided into:

1. **Research honeypots-** These are used by researchers to analyze hacker attacks and deploy different ways to prevent these attacks.
2. **Production honeypots-** Production honeypots are deployed in production networks along with the server. These honeypots act as a frontend trap for the attackers, consisting of false information and giving time to the administrators to improve any vulnerability in the actual system.

Based on interaction, honeypots are classified into:

1. **Low interaction honeypots:** Low interaction honeypots gives very little insight and control to the hacker about the network. It simulates only the services that are frequently requested by the attackers. The main operating system is not involved in the low interaction systems and therefore it is less risky. They require very fewer resources and are easy to deploy. The only disadvantage of these honeypots lies in the fact that experienced hackers can easily identify these honeypots and can avoid it.
2. **Medium Interaction Honeypots:** Medium interaction honeypots allows more activities to the hacker as compared to the low interaction honeypots. They can expect certain activities and are designed to give certain responses beyond what a low-interaction honeypot would give.
3. **High Interaction honeypots:** A high interaction honeypot offers a large no. of services and activities to the hacker, therefore, wasting the time of the hackers and trying to get complete information about the hackers. These honeypots involve the real-time operating system and therefore are comparatively risky if a hacker identifies the honeypot. High interaction honeypots are also very costly and are complex to implement. But it provides us with extensively large information about hackers.

Advantages of honeypot:

1. Acts as a rich source of information and helps collect real-time data.
2. Identifies malicious activity even if encryption is used.
3. Wastes hackers' time and resources.
4. Improves security.

Disadvantages of honeypot:

1. Being distinguishable from production systems, it can be easily identified by experienced attackers.
2. Having a narrow field of view, it can only identify direct attacks.
3. A honeypot once attacked can be used to attack other systems.
4. Fingerprinting (an attacker can identify the true identity of a honeypot).

=====

UNIT II

1. Proxy Server:

Proxy server refers to a server that acts as an intermediary between the request made by clients, and a particular server for some services or requests for some resources. There are different types of proxy servers available that are put into use according to the purpose of a request made by the clients to the servers. The basic purpose of Proxy servers is to protect the direct connection of Internet clients and internet resources. The proxy server also prevents the identification of the client's IP address when the client makes any request is made to any other servers.

- **Internet Client and Internet resources:** For internet clients, Proxy servers also act as a shield for an internal network against the request coming from a client to access the data stored on the server. It makes the original IP address of the node remains hidden while accessing data from that server.
- **Protects true host identity:** In this method, outgoing traffic appears to come from the proxy server rather than internet navigation. It must be configured to the specific application such as HTTPs or FTP. For example, organizations can use a proxy to observe the traffic of its employees to get the work efficiently done. It can also be used to keep a check on any kind of highly confidential data leakage. Some can also use it to increase their websites rank.

Need of Private Proxy:

1. **Defeat Hackers:** To protect organizations data from malicious use, passwords are used and different architects are setup, but still, there may be a possibility that this information can be hacked in case the IP address is accessible easily. To prevent such kind of misuse of Data Proxy servers are set up to prevent tracking of original IP addresses instead data is shown to come from a different IP address.
2. **Filtering of Content:** By caching the content of the websites, Proxy helps in fast access to the data that has been accessed very often.
3. **Examine Packet headers and Payloads:** Payloads and packet headers of the requests made by the user nodes in the internal server to access to social websites can be easily tracked and restricted.
4. **To control internet usage of employees and children:** In this, the Proxy server is used to control and monitor how their employees or kids use the internet. Organizations use it, to deny access to a specific website and instead redirecting you with a nice note asking you to refrain from looking at said sites on the company network.
5. **Bandwidth savings and improved speeds:** Proxy helps organizations to get better overall network performance with a good proxy server.
6. **Privacy Benefits:** Proxy servers are used to browse the internet more privately. It will change the IP address and identify the information the web request contains.
7. **Security:** Proxy server is used to encrypt your web requests to keep prying eyes from reading your transactions as it provides top-level security.

2. Anonymizers

Anonymizers are tools that allow — or attempt to allow — users to make their online activity untraceable.

Anonymizers are proxy servers that act as intermediaries between the client and the actual server. An anonymizer attempts to provide a shield of anonymity by protecting the identification information of the actual systems that are using the service or resources.

There are various types of anonymizers that are available both commercially and for free on the Internet. There are protocol-specific anonymizers, which only understand a specific protocol and can only mediate connections that use a particular protocol.

The manner in which this works is that the client simply initiates a connection to the anonymizer, sending commands to the anonymizer inside a message.

The anonymizer, on receiving the command, would strip out the commands and relay the connection information to the destination server as if it were originating from the anonymizer.

There are protocol-independent anonymizers as well, which effectively tunnel traffic between the server and the client. The protocols that may be used by anonymizer services include OpenVPN, PPTP, SOCKS4, SOCKS5, etc.

Types of proxies

Following are the types of proxies:

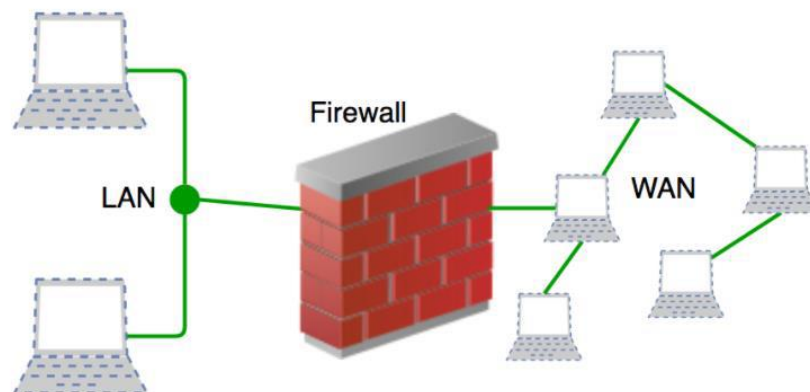
- Transparent proxy – Victim will know you are using a proxy and can trace your real IP
- Anonymous proxy – Victim will know you are using a proxy, but, cannot trace your real IP
- Elite proxy – Victim doesn't know if the communication is from a proxy or not

3. Firewall: -

A firewall is a network security device, either hardware or software-based, which monitors all incoming and outgoing traffic and based on a defined set of security rules it accepts, rejects or drops that specific traffic.

- Accept: allow the traffic.
- Reject: block the traffic but reply with an “unreachable error”.
- Drop: block the traffic with no reply.

- A firewall establishes a barrier between secured internal networks and outside untrusted network, such as the Internet.



Firewall design principles

- The firewall is inserted between the premise network and internet to establish a controlled link and to erect an outer security wall or perimeter.
- The aim of this perimeter is to protect the premises network from internet-based attacks and to provide a single choke point where security and audit can be imposed.
- The firewall can be a single computer system or a set of two or more systems that cooperate to perform the firewall function.

Firewall characteristics:

- All traffic from inside to outside, and vice versa, must pass through the firewall. This is achieved by physically blocking all access to the local network except via the firewall. Various configurations are possible.
- Only authorized traffic, as defined by the local security policy, will be allowed to pass.
- Various types of firewalls are used, which implement various types of security policies.
- The firewall itself is immune to penetration. This implies that use of a trusted system with a secure operating system.
- This implies that use of a trusted system with a secure operating system.
- Four techniques that firewall use to control access and enforce the site's security policy is as follows:
 - Service control – determines the type of internet services that can be accessed, inbound or outbound. The firewall may filter traffic on this basis of IP address and TCP port number; may provide proxy software that receives and interprets each service request before passing it on; or may host the server software itself, such as web or mail service.

- Direction control – determines the direction in which particular service request may be initiated and allowed to flow through the firewall.
- User control – controls access to a service according to which user is attempting to access it.
- Behavior control – controls how particular services are used.

Capabilities of firewall

- A firewall defines a single choke point that keeps unauthorized users out of the protected network, prohibits potentially vulnerable services from entering or leaving the network, and provides protection from various kinds of IP spoofing and routing attacks.
- A firewall provides a location for monitoring security related events. Audits and alarms can be implemented on the firewall system.
- A firewall is a convenient platform for several internet functions that are not security related.
- A firewall can serve as the platform for IPsec.

Types of firewalls

There are 3 common types of firewalls.

- Packet filters
- Application-level gateways
- Circuit-level gateways

➤ Packet filtering router

- A packet filtering router applies a set of rules to each incoming IP packet and then forwards or discards the packet.
- The router is typically configured to filter packets going in both directions.
- Filtering rules are based on the information contained in a network packet:

Source IP address – IP address of the system that originated the IP packet.

Destination IP address – IP address of the system, the IP is trying to reach.

Source and destination transport level address – transport level port number.

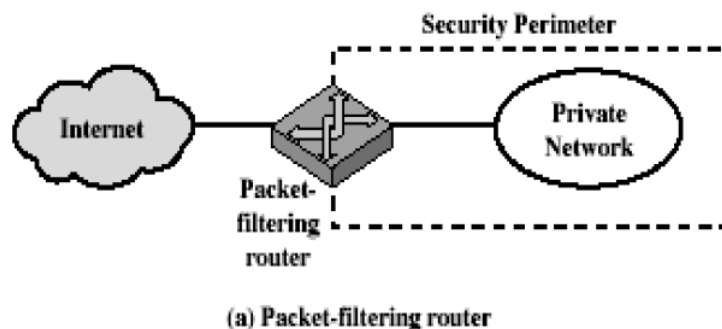
IP protocol field – defines the transport protocol.

Interface – for a router with three or more ports, which interface of the router the packet come from or which interface of the router the packet is destined for.

- The packet filter is typically set up as a list of rules based on matches to fields in the IP or TCP header.
- If there is a match to one of the rules, that rule is invoked to determine whether to forward or discard the packet. If there is no match to any rule, then a default action is taken.

■ Two default policies are possible:

- Default = discard: That which is not expressly permitted is prohibited.
- Default = forward: That which is not expressly prohibited is permitted.



■ **Advantages of packet filter router**

- Simple
- Transparent to users
- Very fast

■ **Weakness of packet filter firewalls**

- Because packet filter firewalls do not examine upper-layer data, they cannot prevent attacks that employ application specific vulnerabilities or functions.
- Because of the limited information available to the firewall, the logging functionality present in packet filter firewall is limited.
- It does not support advanced user authentication schemes.
- They are generally vulnerable to attacks such as layer address spoofing.

➤ **Application-level gateway**

■ An application-level gateway, also called a proxy server, acts as a relay of application-level traffic.

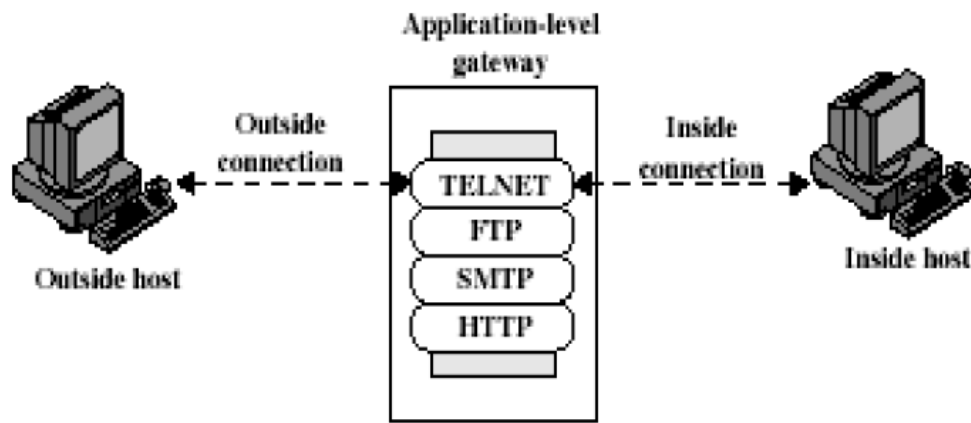
■ The user contacts the gateway using a TCP/IP application, such as Telnet or FTP, and the gateway asks the user for the name of the remote host to be accessed.

■ When the user responds and provides a valid user ID and authentication information, the gateway contacts the application on the remote host and relays TCP segments containing the application data between the two endpoints.

■ Application-level gateways tend to be more secure than packet filters.

■ It is easy to log and audit all incoming traffic at the application level.

■ A prime disadvantage is the additional processing overhead on each connection.



(b) Application-level gateway

➤ Circuit level gateway

- Circuit level gateway can be a stand-alone system or it can be a specified function performed by an application-level gateway for certain applications.

A Circuit level gateway does not permit an end-to-end TCP connection; rather, the gateway sets up two TCP connections, one between itself and a TCP user on an inner host and one between itself and a TCP user on an outer host.

- Once the two connections are established, the gateway typically relays TCP segments from one connection to the other without examining the contents.

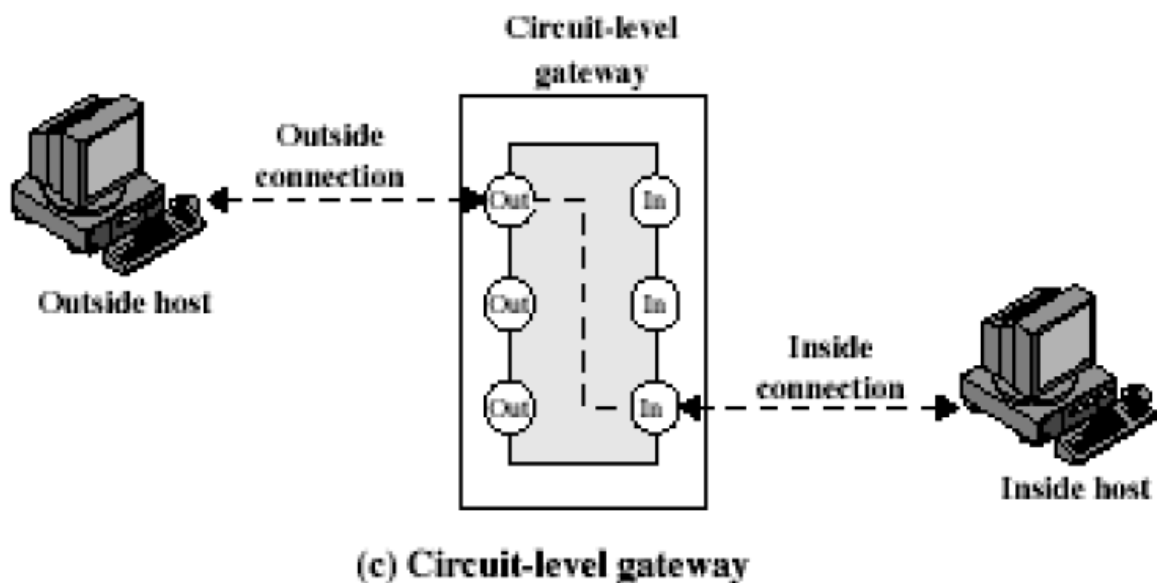
- The security function consists of determining which connections will be allowed.

- Bastion host

- It is a system identified by the firewall administrator as a critical strong point in the network's security.

- The Bastion host serves as a platform for an application level and circuit level gateway.

Common



4. Password Cracking Techniques:

Password crackers use two primary methods to identify correct passwords: brute-force and dictionary attacks. However, there are plenty of other password cracking methods, including the following:

- **Brute force.** This attack runs through combinations of characters of a predetermined length until it finds the combination that matches the password.
- **Dictionary search.** Here, a password cracker searches each word in the dictionary for the correct password. Password dictionaries exist for a variety of topics and combinations of topics, including politics, movies and music groups.
- **Phishing.** These attacks are used to gain access to user passwords without the use of a password cracking tool. Instead, a user is fooled into clicking on an email attachment. From here, the attachment could install malware or prompt the user to use their email to sign into a false version of a website, revealing their password.
- **Malware.** Similar to phishing, using malware is another method of gaining unauthored access to passwords without the use of a password cracking tool. Malware such as keyloggers, which track keystrokes, or screen scrapers, which take screenshots, are used instead.
- **Rainbow attack.** This approach involves using different words from the original password in order to generate other possible passwords. Malicious actors can keep a list called a rainbow table with them. This list contains leaked and

previously cracked passwords, which will make the overall password cracking method more effective.

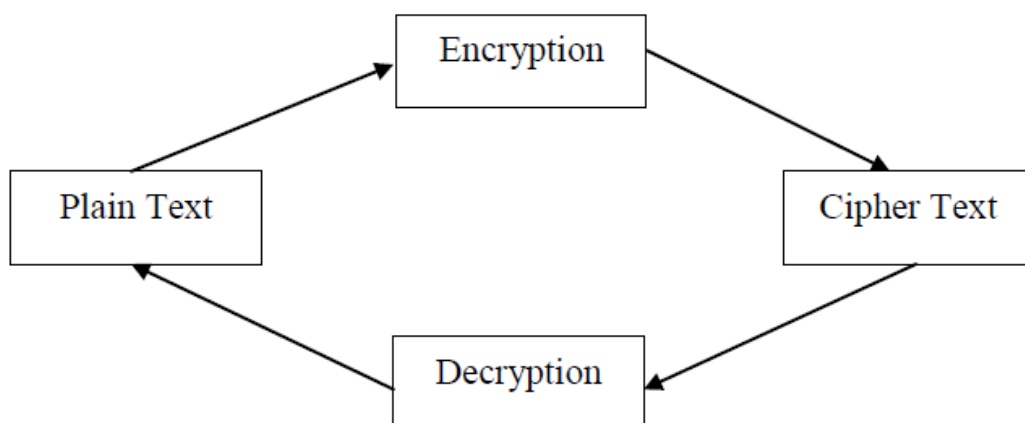
- **Guessing.** An attacker may be able to guess a password without the use of tools. If the threat actor has enough information about the victim or the victim is using a common enough password, they may be able to come up with the correct characters.

Some password cracking programs may use hybrid attack methodologies where they search for combinations of dictionary entries and numbers or special characters. For example, a password cracker may search for ants01, ants02, ants03, etc. This can be helpful when users have been advised to include a number in their password.

5. Cryptography:

The word is derived from the Greek crypto“s, meaning hidden. Cryptography is a science of devising methods that allow information to be sent in a secure form in such a way that the only person to able retrieve this information is the intended recipient.

Encryption is based on algorithms that scramble information (Plaintext or Clear Text) into unreadable (Cipher Text) form. Decryption is the process of restoring the scrambled information to its original form. Cryptography includes techniques such as microdots, merging words with images, and other ways to hide information in storage or transit.



➤ Plaintext

Plaintext can refer to anything which humans can understand and/or relate to. This may be as simple as English sentences, a script, or Java code. If you can make sense of what is written, then it is in plaintext.

➤ **Ciphertext**

Ciphertext, or encrypted text, is a series of randomized letters and numbers which humans cannot make any sense of. An encryption algorithm takes in a plaintext message, runs the algorithm on the plaintext, and produces a ciphertext. The ciphertext can be reversed through the process of decryption, to produce the original plaintext.

➤ **Encryption**

Encryption is a process which transforms the original information into an unrecognizable form. This new form of the message is entirely different from the original message. That's why a hacker is not able to read the data as senders use an encryption algorithm. Encryption is usually done using key algorithms.

Data is encrypted to make it safe from stealing. However, many known companies also encrypt data to keep their trade secret from their competitors.

➤ **Decryption**

Decryption is a process of converting encoded/encrypted data in a form that is readable and understood by a human or a computer. This method is performed by un-encrypting the text manually or by using keys used to encrypt the original data.

Types of Keys

- **Symmetric Key:**

Symmetric-key encryption are algorithms which use the same cryptographic keys for both encryption of plaintext and decryption of ciphertext.

- **Asymmetric Key:**

Asymmetric encryption uses 2 pairs of key for encryption. Public key is available to anyone while the secret key is only made available to the receiver of the message. This boosts security.

- **Public Key:**

Public key cryptography is an encryption system which is based on two pairs of keys. Public keys are used to encrypt messages for a receiver.

- **Private Key:**

Private key may be part of a public/ private asymmetric key pair. It can be used in asymmetric encryption as you can use the same key to encrypt and decrypt data.

- **Pre-Shared Key:**

In cryptography, a pre-shared key (PSK) is a shared secret which was earlier shared between the two parties using a secure channel before it is used.

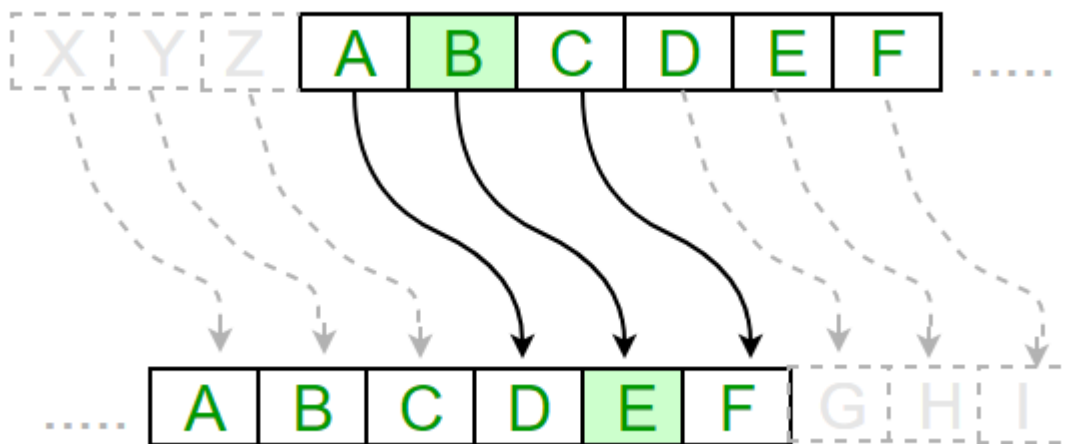
6. Caesar Cipher,

The Caesar Cipher technique is one of the earliest and simplest methods of encryption technique. It's simply a type of substitution cipher, i.e., each letter of a given text is replaced by a letter with a fixed number of positions down the alphabet. For example, with a shift of 1, A would be replaced by B, B would become C, and so on. The method is apparently named after Julius Caesar, who apparently used it to communicate with his officials.

Thus, to cipher a given text we need an integer value, known as a shift which indicates the number of positions each letter of the text has been moved down. The encryption can be represented using modular arithmetic by first transforming the letters into numbers, according to the scheme, A = 0, B = 1,..., Z = 25. Encryption of a letter by a shift n can be described mathematically as.

(Encryption Phase with shift n)

(Decryption Phase with shift n)



Examples:

Text : ABCDEFGHIJKLMNOPQRSTUVWXYZ

Shift: 23

Cipher: XYZABCDEFGHIJKLMNOPQRSTUVWXYZ

Text : ATTACKATONCE

Shift: 4

Cipher: EXXEGOEXSRGI

7. Substitution Techniques

Substitution technique is a classical encryption technique where the characters present in the original message are replaced by the other characters or numbers or by symbols. If the plain text (original message) is considered as the string of bits, then the substitution technique would replace bit pattern of plain text with the bit pattern of cipher text.

The following substitution techniques are:

Substitution Technique:

- Caesar Cipher.
- Modified version of Caesar cipher.
- Monoalphabetic cipher.
- Homophonic cipher.
- Polygram substitution cipher.
- Polyalphabetic substitution cipher.

8. Substitution Boxes (SBoxes),

In cryptography, an S-box (substitution-box) is a basic component of symmetric key algorithms which performs substitution. In block ciphers, they are typically used to obscure the relationship between the key and the ciphertext. Mathematically, an S-box is a vectorial Boolean function.

In general, an S-box takes some number of input bits, m , and transforms them into some number of output bits, n , where n is not necessarily equal to m . An $m \times n$ S-box can be implemented as a lookup table with 2^m words of n bits each. Fixed tables are normally used, as in the Data Encryption Standard (DES), but in some ciphers the tables are generated dynamically from the key.

S-Box Substitution is a procedure that accepts the 48-bit input from the XOR operation containing the compressed key and expanded RPT and creates a 32-bit output utilizing the substitution technique.

The substitution is implemented by the eight substitution boxes (also known as the S-boxes). Each 8-S-boxes has a 6-bit input and a 4-bit output. The 48-bit input block is divided into 8 sub-blocks (each including 6 bits), and each sub-blocks is provided to an S-box.

The substitution in each box follows a pre-decided rule depends on a 4-row by 16- column table. The sequence of bits one and six of the input represent four rows and the sequence of bits two through five represent sixteen columns.

Because each S-box has its own table, we require eight tables, as display in table 1 to table 8, to represent the output of these boxes. The values of the inputs (row number and column number) and the values of the outputs are given as decimal numbers to store space. These need to be changed to binary.

S-Box 1

14	4	13	1	2	15	11	8	3	10	6	12	5	9	0	7
0	15	7	4	14	2	13	1	10	6	12	11	9	5	3	8
4	1	14	8	13	6	2	11	15	12	9	7	3	10	5	0
15	12	8	2	4	9	1	7	5	11	3	14	10	0	6	13

S-Box 2

15	1	8	14	6	11	3	4	9	7	2	13	12	0	5	10
3	13	4	7	15	2	8	14	12	0	1	10	6	9	11	5
0	14	7	11	10	4	13	1	5	8	12	6	9	3	2	15
13	8	10	1	3	15	4	2	11	6	7	12	0	5	14	9

S-Box 3

10	0	9	14	6	3	15	5	1	13	12	7	11	4	2	8
13	7	0	9	3	4	6	10	2	8	5	14	12	11	15	1
13	6	4	9	8	15	3	0	11	1	2	12	5	10	14	7
1	10	13	0	6	9	8	7	4	15	14	3	11	5	2	12

S-Box 4

7	13	14	3	0	6	9	10	1	2	8	5	11	12	4	15
13	8	11	5	6	15	0	3	4	7	2	12	1	10	14	9
10	6	9	0	12	11	7	13	15	1	3	14	5	2	8	4
3	15	0	6	10	1	13	8	9	4	5	11	12	7	2	14

S-Box 5

2	12	4	1	7	10	11	6	8	5	3	15	13	0	14	9
14	11	2	12	4	7	13	1	5	0	15	10	3	9	8	6
4	2	1	11	10	13	7	8	15	9	12	5	6	3	0	14
11	8	12	7	1	14	2	13	6	15	0	9	10	4	5	3

S-Box 6

12	1	10	15	9	2	6	8	0	13	3	4	14	7	5	11
10	15	4	2	7	12	9	5	6	1	13	14	0	11	3	8
9	14	15	5	2	8	12	3	7	0	4	10	1	13	11	6

4	3	2	12	9	5	15	10	11	14	1	7	6	0	8	13
---	---	---	----	---	---	----	----	----	----	---	---	---	---	---	----

S-Box 7

4	11	2	14	15	0	8	13	3	12	9	7	5	10	6	1
13	0	11	7	4	9	1	10	14	3	5	12	2	15	8	6
1	4	11	13	12	3	7	14	10	15	6	8	0	10	9	2
6	11	13	8	1	4	10	7	9	5	0	15	14	0	3	12

S-Box 8

13	2	8	4	6	15	11	1	10	9	3	14	5	0	12	7
1	15	13	8	10	3	7	4	12	5	6	11	0	14	9	2
7	11	4	1	9	12	14	2	0	6	10	13	15	3	5	8
2	1	14	7	4	10	8	13	15	12	9	0	3	5	6	11

One good example of a fixed table is the S-box from DES (S_5), mapping 6-bit input into a 4-bit output:

S_5		Middle 4 bits of input															
		0000	0001	0010	0011	0100	0101	0110	0111	1000	1001	1010	1011	1100	1101	1110	1111
Outer bits	00	0010	1100	0100	0001	0111	1010	1011	0110	1000	0101	0011	1111	1101	0000	1110	1001
	01	1110	1011	0010	1100	0100	0111	1101	0001	0101	0000	1111	1010	0011	1001	1000	0110
	10	0100	0010	0001	1011	1010	1101	0111	1000	1111	1001	1100	0101	0110	0011	0000	1110
	11	1011	1000	1100	0111	0001	1110	0010	1101	0110	1111	0000	1001	1010	0100	0101	0011

Given a 6-bit input, the 4-bit output is found by selecting the row using the outer two bits (the first and last bits), and the column using the inner four bits. For example, an input "011011" has outer bits "01" and inner bits "1101"; the corresponding output would be "1001".

The eight S-boxes of DES were the subject of intense study for many years out of a concern that a backdoor (a vulnerability known only to its designers) might have been planted in the cipher.

9. Transposition Techniques

Transposition technique (No replacement of character) is an encryption method which is achieved by performing permutation over the plain text. Mapping plain text into cipher text using transposition technique is called transposition cipher.

On the one hand, the substitution technique substitutes a plain text symbol with a cipher text symbol. On the other hand, the transposition technique executes permutation on the plain text to obtain the cipher text.

The Following Transposition Techniques are:

- Rail Fence Technique.
- Simple Columnar Transposition Technique.
- Simple Columnar Transposition Technique with multiple rounds.
- Vernam Cipher (one – Time Pad).
- Book Cipher/Running Key Cipher.
- Playfair Cipher.
- Hill Cipher.

10. Symmetric & Asymmetric key Cryptography,

➤ Symmetric Key Cryptography

In symmetric key cryptography, an individual key is used for both encryption and decryption. The sender needs the key to encrypt the plaintext and sends the cipher document to the receiver. The receiver used the similar key (or ruleset) to decrypt the message and recover the plaintext. Because an individual key is used for both functions, symmetric key cryptography is also known as symmetric encryption.

Symmetric key cryptography schemes are usually categorized such as stream ciphers or block ciphers. Stream ciphers works on a single bit (byte or computer word) at a time and execute some form of feedback structure so that the key is constantly changing.

➤ Asymmetric cryptography

Asymmetric cryptography uses two keys for encryption and decryption. It depends on the technique of public and private keys. A public key, which is interchanged between higher than one user. Data is decrypted by a private key, which is not transformed. It is slower but more secure. The public key used in this encryption technique is applicable to everyone, but the private key used in it is not revealed.

In asymmetric encryption, a message that is encrypted utilizing a public key can be decrypted by a private key, while if the message is encrypted by a private key can be

decrypted by utilizing the public key. Asymmetric encryption is broadly used in day-to-day communication channels, particularly on the internet.

Let us see the comparison between Symmetric Key Cryptography and Asymmetric Key Cryptography.

Symmetric Key Cryptography	Asymmetric Key Cryptography
There is only one key (symmetric key) is used, and the similar key can be used to encrypt and decrypt the message.	There are two different cryptographic keys (asymmetric keys), known as the public and the private keys, are used for encryption and decryption.
It is effective as this technique is recommended for high amounts of text.	It is inefficient as this approach is used only for short messages.
Symmetric encryption is generally used to transmit bulk information.	It is generally used in smaller transactions. It is used for making a secure connection channel before transferring the actual information.
Symmetric key cryptography is also known as secret-key cryptography or private key cryptography.	Asymmetric key cryptography is also known as public-key cryptography or a conventional cryptographic system.
Symmetric key cryptography uses fewer resources as compared to asymmetric key cryptography.	Asymmetric key cryptography uses more resources as compared to symmetric key cryptography.
The length of the keys used is frequently 128 or 256 bits, based on the security need.	The length of the keys is much higher, such as the recommended RSA key size is 2048 bits or higher.

11. Key Range & Key Size:

The concept of key range and key-size are related to each other. Key Range is total number of keys from smallest to largest available key. An attacker usually is armed with the knowledge of the cryptographic algorithm and the encrypted message, so only the actual key value remains the challenge for the attacker.

- If the key is found, the attacker can get original plaintext message. In the brute force attack, every possible key in the key-range is tried, until we get the right key.
- In the best case, the right key is found in the first attempt, in the worst case, the key is found in the last attempt. On an average, the right key is found after trying half of the possible keys in the key-range. Therefore, by expanding the key range to a large extent, longer it will take for an attacker to find the key using brute-force attack.
- The concept of key range leads to the principle of key size. The strength of a cryptographic key is measured with the key size
- Key size is measured in bits and is represented using binary number system. Thus, if the key ranges from 0 to 8, then the key size is 3 bits or in other words we can say if the size is bits, then the key range is 0 to 256. Key size may be varying, depending upon the applications and the cryptographic algorithm being used, it can be 40 bits, 56 bits, 128 bits & so on. In order to protect the cipher-text against the brute-force attack, the key-size should be such that the attacker cannot crack it within a specified amount of time.
- From a practical viewpoint, a 40-bit key takes about 3 hours to crack, however a 41-bit key would take 6 hours and 42-bit key would take 12 hours & so on. This means every additional bit doubles the amount of time required to crack the key. We can assume that 128-bit key is quite safe, considering the capabilities of today's computers. However, as the computing power and techniques improve, these numbers will change in future.

=====

Unit-III

1. Symmetric Key Algorithm:

Symmetric key cryptography is a type of encryption scheme in which the similar key is used both to encrypt and decrypt messages. Such an approach of encoding data has been largely used in the previous decades to facilitate secret communication between governments and militaries.

Symmetric-key cryptography is called a shared-key, secret-key, single-key, one-key and eventually private-key cryptography. With this form of cryptography, it is clear that the key should be known to both the sender and the receiver that the shared. The complexity with this approach is the distribution of the key.

Symmetric key cryptography schemes are usually categorized such as stream ciphers or block ciphers. Stream ciphers work on a single bit (byte or computer word) at a time and execute some form of feedback structure so that the key is repeatedly changing.

A block cipher is so-called because the scheme encrypts one block of information at a time utilizing the same key on each block. In general, the same plaintext block will continually encrypt to the same ciphertext when using the similar key in a block cipher whereas the same plaintext will encrypt to different ciphertext in a stream cipher.

2. Block Ciphers:

A block cipher is a method of encrypting data in blocks to produce ciphertext using a cryptographic key and algorithm. The block cipher processes fixed-size blocks simultaneously, as opposed to a stream cipher, which encrypts data one bit at a time. Most modern block ciphers are designed to encrypt data in fixed-size blocks of either 64 or 128 bits.

How does a block cipher work?

A block cipher uses a symmetric key and algorithm to encrypt and decrypt a block of data. A block cipher requires an initialization vector (IV) that is added to the input plaintext in order to increase the key space of the cipher and make it more difficult to use brute force to break the key. The IV is derived from a random number generator, which is combined with text in the first block and the key to ensure all subsequent blocks result in ciphertext that does not match that of the first encryption block.

The block size of a block cipher refers to the number of bits that are processed together. Data Encryption Standard (DES) and Advanced Encryption Standard (AES) are both symmetric block ciphers.

The DES block cipher was originally designed by IBM in 1975 and consisted of 64-bit blocks and a 56-bit key. This cipher is not considered secure anymore, due to the short key size, and was replaced in 1998 by AES. AES uses a 128-bit block size and a 128-, 192- or 256-bit key size.

What are the different modes of operation in block cipher?

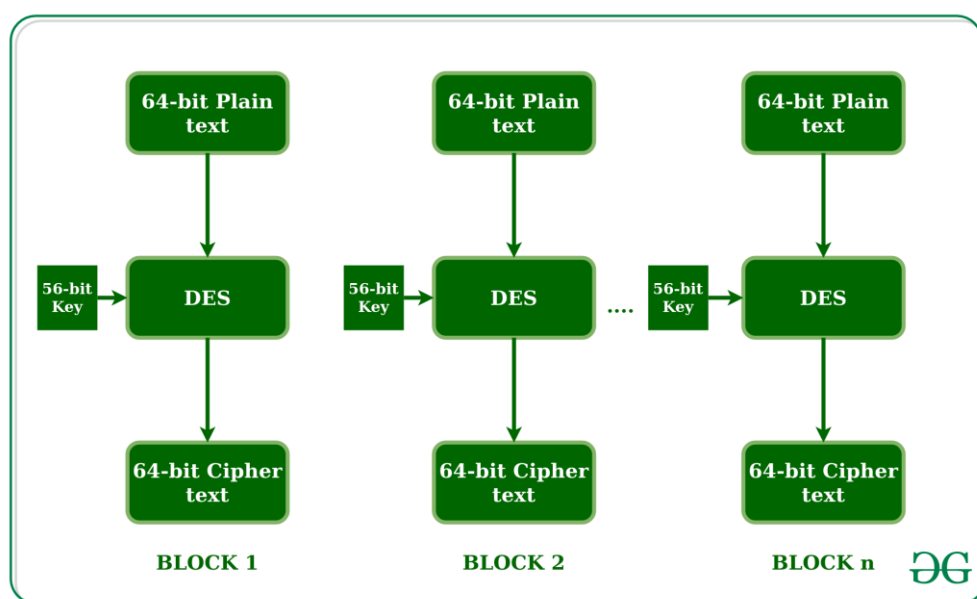
Block ciphers only encrypt messages that are the same size as their block length, so each block of plaintext with more or less blocks needs to be encrypted separately. The following block cipher modes of operation define how these blocks are encrypted:

- **Electronic codebook (ECB) mode.** ECB mode is used to electronically code messages as their plaintext form. It is the simplest of all block cipher modes of operation. It does not add any randomness to the key stream, and it is the only mode that can be used to encrypt a single-bit stream. This means that each plaintext symbol, such as a character from the plaintext alphabet, is converted into a ciphertext symbol using the cipher's key and a substitution alphabet. Each plaintext block is encrypted independently of all the other blocks. If a plaintext block is only 8 bytes, only 8 bytes of the key are used; if a plaintext block is 100 bytes, all 100 bytes of the key are used.
- **Cipher block chaining (CBC) mode.** CBC mode is a method of encrypting data that ensures that each block of plaintext is combined with the previous ciphertext block before being encrypted. The symmetric key algorithm creates a ciphertext that depends on all plaintext blocks processed before it in a data stream. This is done to ensure that each block of the ciphertext is dependent on all of the previous blocks. Each plaintext block is XORed (exclusive OR) with the previous ciphertext block before being encrypted with the cipher algorithm. CBC mode is used in a variety of security applications. For example, Secure Sockets Layer/Transport Layer Security uses CBC mode to encrypt data that is transferred over the internet.
- **Ciphertext feedback (CFB) mode.** In contrast to CBC mode, which encrypts a set number of bits of plaintext at a time, it is sometimes necessary to encrypt and transfer plaintext values instantly, one at a time. Like CBC, CFB also uses an IV. CFB uses a block cipher as a component of a random number generator. In CFB mode, the previous ciphertext block is encrypted, and the output is XORed with the current plaintext block to create the current ciphertext block. The XOR operation conceals plaintext patterns.

- **Output feedback (OFB) mode.** OFB mode can be used with any block cipher and is similar in some respects to CBC mode. It uses a feedback mechanism, but instead of XORing the previous block of ciphertext with the plaintext before encryption, in OFB mode, the previous block of ciphertext is XORed with the plaintext after it is encrypted.
- **Counter (CTR) mode.** CTR mode uses a block chaining mode of encryption as a building block. The process of encrypting data is performed by XORing the plaintext with a sequence of pseudorandom values, each of which is generated from the ciphertext using a feedback function. The CTR encryption process can be visualized as a series of XORs between blocks of plaintext and corresponding blocks of ciphertext.

3. DES (Data Encryption Standard) Algorithm:

Data encryption standard (DES) has been found vulnerable to very powerful attacks and therefore, the popularity of DES has been found slightly on the decline. DES is a block cipher and encrypts data in blocks of size of **64 bits** each, which means 64 bits of plain text go as the input to DES, which produces 64 bits of ciphertext. The same algorithm and key are used for encryption and decryption, with minor differences. The key length is **56 bits**. The basic idea is shown in the figure:



We have mentioned that DES uses a 56-bit key. Actually, the initial key consists of 64 bits. However, before the DES process even starts, every 8th bit of the key is discarded to produce a 56-bit key. That is bit positions 8, 16, 24, 32, 40, 48, 56, and 64 are discarded.

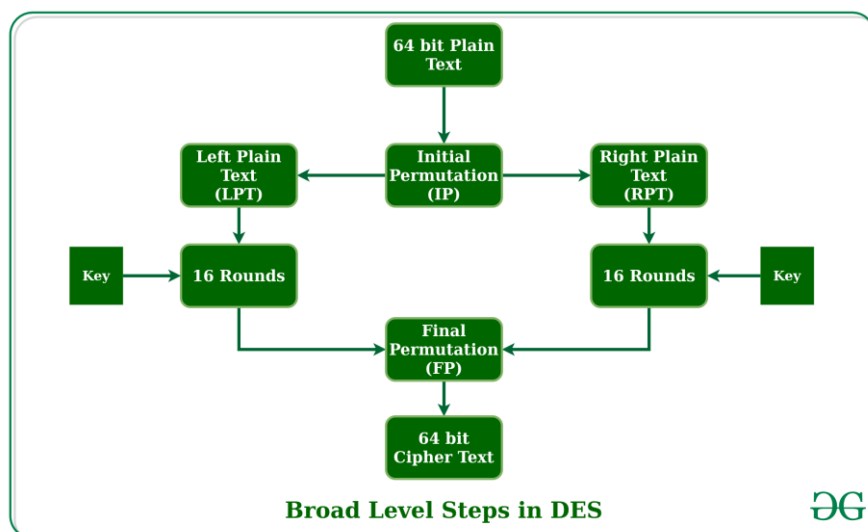
1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
17	18	19	20	21	22	23	24	25	26	27	28	29	30	31	32
33	34	35	36	37	38	39	40	41	42	43	44	45	46	47	48
49	50	51	52	53	54	55	56	57	58	59	60	61	62	63	64

Figure - discarding of every 8th bit of original key

Thus, the discarding of every 8th bit of the key produces a **56-bit key** from the original **64-bit key**.

DES is based on the two fundamental attributes of cryptography: substitution (also called confusion) and transposition (also called diffusion). DES consists of 16 steps, each of which is called a round. Each round performs the steps of substitution and transposition. Let us now discuss the broad-level steps in DES.

- In the first step, the 64-bit plain text block is handed over to an initial Permutation (IP) function.
- The initial permutation is performed on plain text.
- Next, the initial permutation (IP) produces two halves of the permuted block; saying Left Plain Text (LPT) and Right Plain Text (RPT).
- Now each LPT and RPT go through 16 rounds of the encryption process.
- In the end, LPT and RPT are rejoined and a Final Permutation (FP) is performed on the combined block
- The result of this process produces 64-bit ciphertext.



Initial Permutation (IP):

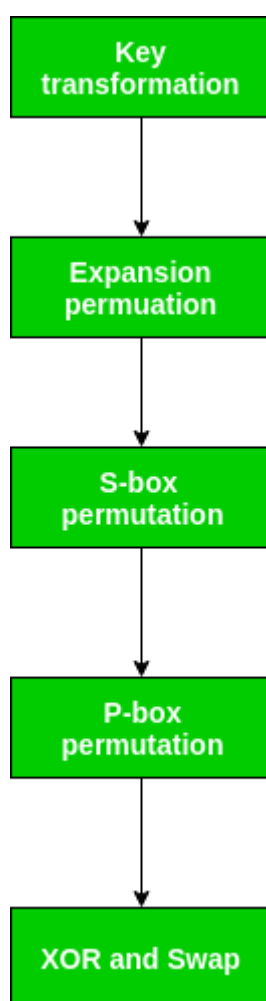
As we have noted, the initial permutation (IP) happens only once and it happens before the first round. It suggests how the transposition in IP should proceed, as shown in the figure. For example, it says that the IP replaces the first bit of the original plain text block with the 58th bit of the original plain text block, the second bit with the 50th bit of the original plain text block, and so on.

This is nothing but jugglery of bit positions of the original plain text block. the same rule applies to all the other bit positions shown in the figure.

58	50	42	34	26	18	10	2	60	52	44	36	28	20	12	4
62	54	46	38	30	22	14	6	64	56	48	40	32	24	16	8
57	49	41	33	25	17	9	1	59	51	43	35	27	19	11	3
61	33	45	37	29	21	13	5	63	55	47	39	31	23	15	7

Figure - Initial permutation table

As we have noted after IP is done, the resulting 64-bit permuted text block is divided into two half blocks. Each half-block consists of 32 bits, and each of the 16 rounds, in turn, consists of the broad-level steps outlined in the figure.



Step-1: Key transformation:

We have noted initial 64-bit key is transformed into a 56-bit key by discarding every 8th bit of the initial key. Thus, for each a 56-bit key is available. From this 56-bit key, a different 48-bit Sub Key is generated during each round using a process called key transformation. For this, the 56-bit key is divided into two halves, each of 28 bits. These halves are circularly shifted left by one or two positions, depending on the round.

For example: if the round numbers 1, 2, 9, or 16 the shift is done by only one position for other rounds, the circular shift is done by two positions. The number of key bits shifted per round is shown in the figure.

Round	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
#key bits shifted	1	1	2	2	2	2	2	2	1	2	2	2	2	2	2	1

Figure - number of key bits shifted per round

After an appropriate shift, 48 of the 56 bits are selected. for selecting 48 of the 56 bits the table is shown in the figure given below. For instance, after the shift, bit number 14 moves to the first position, bit number 17 moves to the second position, and so on. If we observe the table carefully, we will realize that it contains only 48-bit positions. Bit number 18 is discarded (we will not find it in the table), like 7 others, to reduce a 56-bit key to a 48-bit key. Since the key transformation process involves permutation as well as a selection of a 48-bit subset of the original 56-bit key it is called Compression Permutation.

14	17	11	24	1	5	3	28	15	6	21	10
23	19	12	4	26	8	16	7	27	20	13	2
41	52	31	37	47	55	30	40	51	45	33	48
44	49	39	56	34	53	46	42	50	36	29	32

Figure - compression permutation

Because of this compression permutation technique, a different subset of key bits is used in each round. That makes DES not easy to crack.

Step-2: Expansion Permutation:

Recall that after the initial permutation, we had two 32-bit plain text areas called Left Plain Text (LPT) and Right Plain Text(RPT). During the expansion permutation, the RPT is expanded from 32 bits to 48 bits. Bits are permuted as well hence called expansion permutation. This happens as the 32-bit RPT is divided into 8 blocks, with each block consisting of 4 bits. Then, each 4-bit block of the previous step is then expanded to a corresponding 6-bit block, i.e., per 4-bit block, 2 more bits are added.

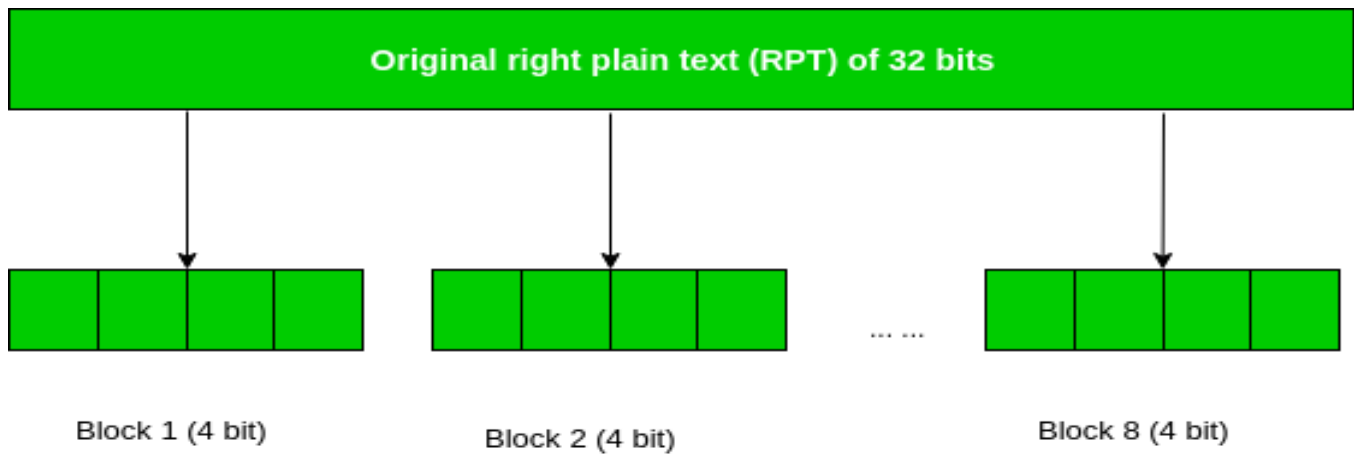


Figure - division of 32 bit RPT into 8 bit blocks

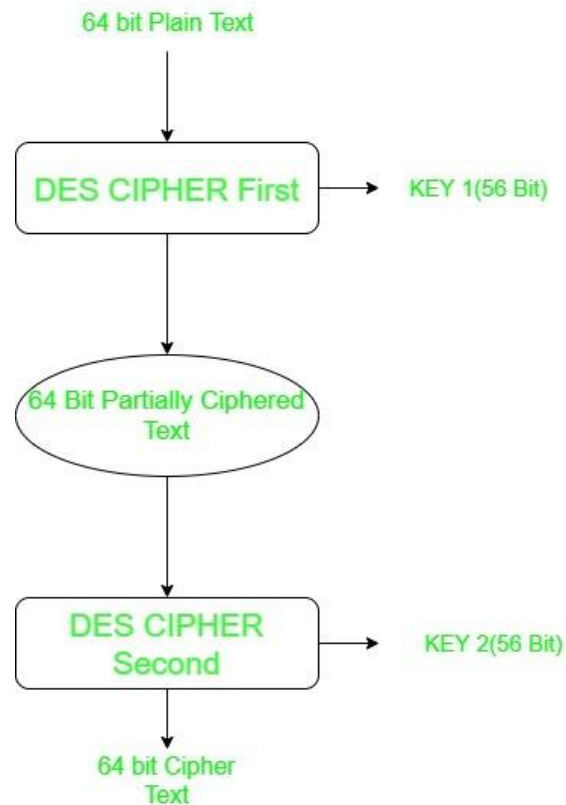
This process results in expansion as well as a permutation of the input bit while creating output. The key transformation process compresses the 56-bit key to 48 bits. Then the expansion permutation process expands the **32-bit RPT** to **48-bits**. Now the 48-bit key is XOR with 48-bit RPT and the resulting output is given to the next step, which is the **S-Box substitution**.

4. Double DES

As we know the Data encryption standard (DES) uses 56 bit key to encrypt any plain text which can be easily be cracked by using modern technologies. To prevent this from happening double DES and triple DES were introduced which are much more secured than the original DES because it uses 112 and 168 bit keys respectively. They offer much more security than DES.

Double DES:

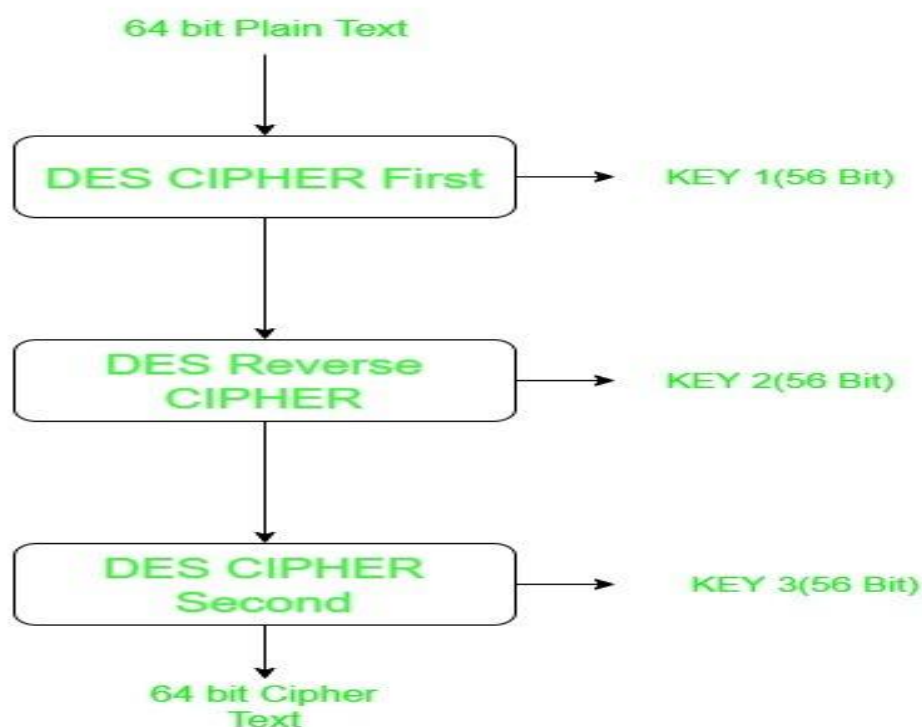
Double DES is a encryption technique which uses two instance of DES on same plain text. In both instances it uses different keys to encrypt the plain text. Both keys are required at the time of decryption. The 64-bit plain text goes into first DES instance which then converted into a 64-bit middle text using the first key and then it goes to second DES instance which gives 64-bit cipher text by using second key.



However double DES uses 112 bit key but gives security level of 2^{56} not 2^{112} and this is because of meet-in-the middle attack which can be used to break through double DES.

5. Triple DES:

Triple DES is a encryption technique which uses three instance of DES on same plain text. It uses their different types of keys choosing technique in first all used keys are different and in second two keys are same and one is different and in third all keys are same.



Triple DES is also vulnerable to meet-in-the middle attack because of which it give total security level of 2^{112} instead of using 168 bit of key. The block collision attack can also be done because of short block size and using same key to encrypt large size of text. It is also vulnerable to sweet32 attack.

6. AES (Advanced Encryption Standard)

The more popular and widely adopted symmetric encryption algorithm likely to be encountered nowadays is the Advanced Encryption Standard (AES). It is found at least six time faster than triple DES.

A replacement for DES was needed as its key size was too small. With increasing computing power, it was considered vulnerable against exhaustive key search attack. Triple DES was designed to overcome this drawback but it was found slow.

The features of AES are as follows –

- Symmetric key, symmetric block cipher
- 128-bit data, 128/192/256-bit keys
- Stronger and faster than Triple-DES
- Provide full specification and design details
- Software implementable in C and Java

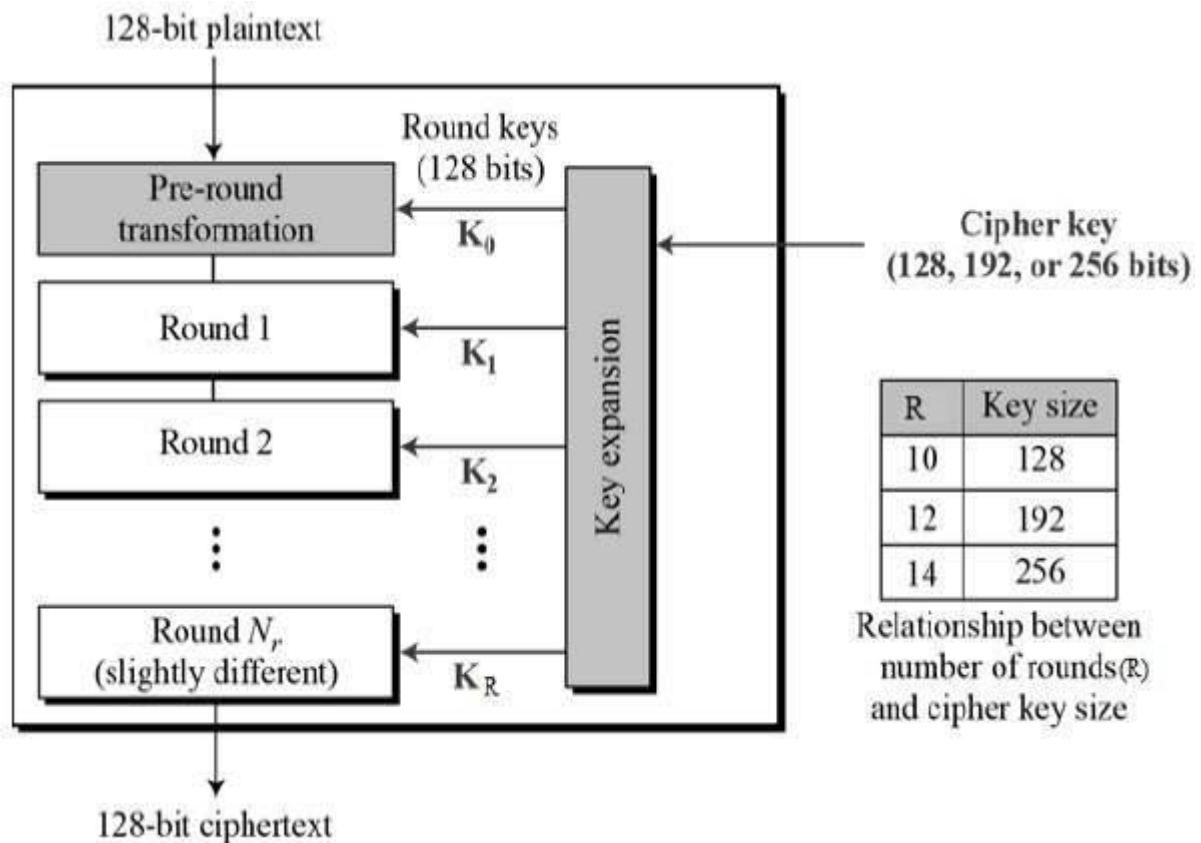
Operation of AES

AES is an iterative rather than Feistel cipher. It is based on ‘substitution–permutation network’. It comprises of a series of linked operations, some of which involve replacing inputs by specific outputs (substitutions) and others involve shuffling bits around (permutations).

Interestingly, AES performs all its computations on bytes rather than bits. Hence, AES treats the 128 bits of a plaintext block as 16 bytes. These 16 bytes are arranged in four columns and four rows for processing as a matrix –

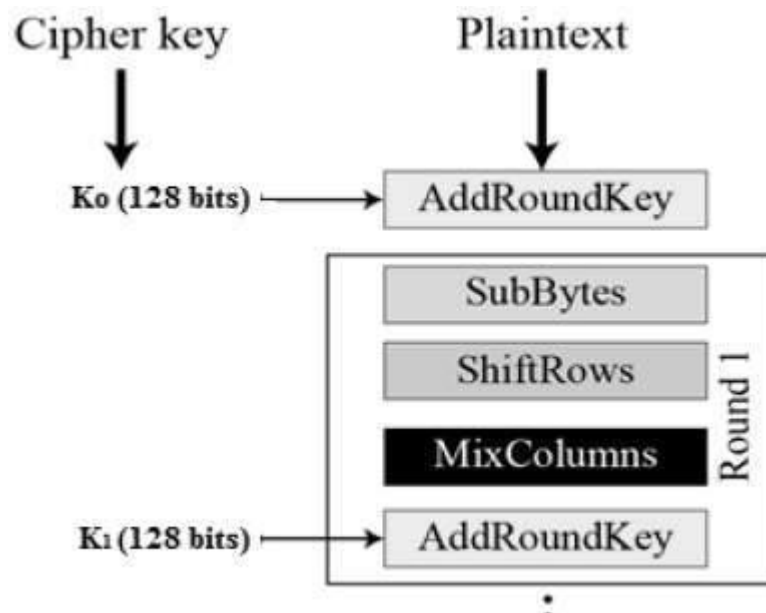
Unlike DES, the number of rounds in AES is variable and depends on the length of the key. AES uses 10 rounds for 128-bit keys, 12 rounds for 192-bit keys and 14 rounds for 256-bit keys. Each of these rounds uses a different 128-bit round key, which is calculated from the original AES key.

The schematic of AES structure is given in the following illustration –



Encryption Process

Here, we restrict to description of a typical round of AES encryption. Each round comprise of four sub-processes. The first round process is depicted below –



Byte Substitution (SubBytes)

The 16 input bytes are substituted by looking up a fixed table (S-box) given in design. The result is in a matrix of four rows and four columns.

Shift rows

Each of the four rows of the matrix is shifted to the left. Any entries that ‘fall off’ are re-inserted on the right side of row. Shift is carried out as follows –

- First row is not shifted.
- Second row is shifted one (byte) position to the left.
- Third row is shifted two positions to the left.
- Fourth row is shifted three positions to the left.
- The result is a new matrix consisting of the same 16 bytes but shifted with respect to each other.

Mix Columns

Each column of four bytes is now transformed using a special mathematical function. This function takes as input the four bytes of one column and outputs four completely new bytes, which replace the original column. The result is another new matrix consisting of 16 new bytes. It should be noted that this step is not performed in the last round.

Add round key

The 16 bytes of the matrix are now considered as 128 bits and are XORed to the 128 bits of the round key. If this is the last round then the output is the ciphertext. Otherwise, the resulting 128 bits are interpreted as 16 bytes and we begin another similar round.

Decryption Process

The process of decryption of an AES ciphertext is similar to the encryption process in the reverse order. Each round consists of the four processes conducted in the reverse order –

- Add round key
- Mix columns
- Shift rows
- Byte substitution

Since sub-processes in each round are in reverse manner, unlike for a Feistel Cipher, the encryption and decryption algorithms need to be separately implemented, although they are very closely related.

AES Analysis

In present day cryptography, AES is widely adopted and supported in both hardware and software. Till date, no practical cryptanalytic attacks against AES have been discovered. Additionally, AES has built-in flexibility of key length, which allows a degree of ‘future-proofing’ against progress in the ability to perform exhaustive key searches.

However, just as for DES, the AES security is assured only if it is correctly implemented and good key management is employed.

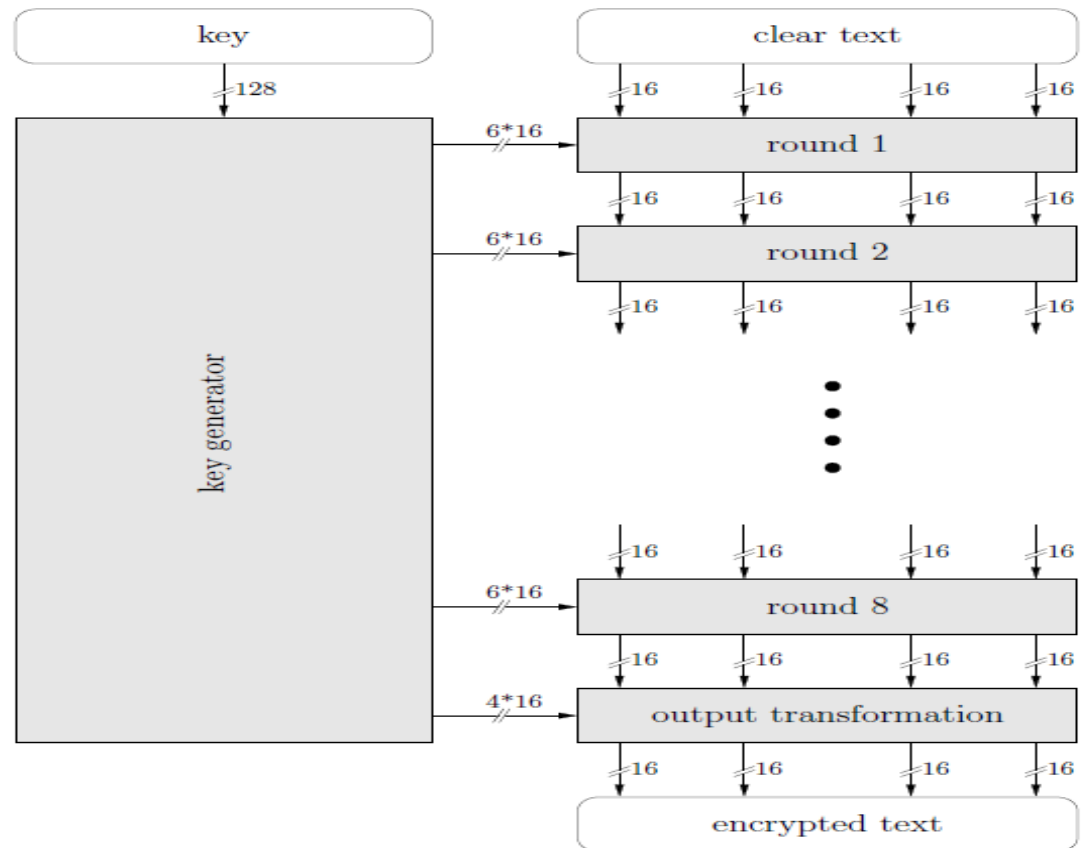
7.IDEA (International Data Encryption Algorithm).

Understanding IDEA

IDEA was developed at ETH, a research university in Zurich, Switzerland, and is generally considered to be secure. The IDEA cipher encrypts text with the assumption that security in IDEA is not predicated on keeping the algorithm a secret, but rather on ignorance of the secret key.

IDEA uses a 128-bit key and operates on 64-bit blocks. Essentially, it encrypts a 64-bit block of plaintext into a 64-bit block of ciphertext. This input plaintext block is divided into four subblocks of 16 bits each. It consists of a series of eight identical transformations, where each transformation is known as a round, as well as an output transformation, which is known as a half-round. Similar to the 16-bit plaintext block, the ciphertext block is also the exact same size.

A block cipher operates in round blocks, with part of the encryption key, known as round key, applied to each round, followed by other mathematical operations. After a certain number of rounds, the ciphertext for that block is generated.



Encryption in IDEA

IDEA derives most of its security from multiple interleaved mathematical operations:

- Modular Addition
- Modular Multiplication
- Bitwise Exclusive-OR (XOR)

By using a 128-bit key, IDEA encrypts a 64-bit block of plaintext into a 64-bit block of ciphertext. One process partitions the plaintext block into four 16-bit subblocks for each of the eight complete rounds, namely X1, X2, X3 and X4.

Another process produces six 16-bit key subblocks for each of the encryption rounds, namely Z1, Z2, Z3, Z4, Z5 and Z6. For subsequent output transformation, a further four 16-bit key subblocks are required. Thus, from a 128-bit key, a total of 52, 16-bit subblocks are generated.

In each complete round, three algebraic operations are performed: bitwise XOR, addition modulo 2^{16} and multiplication modulo $2^{16}+1$.

The 14 steps for a complete round are the following:

1. Multiply X1 with Z1.
2. Add X2 to Z2.
3. Add X3 to Z3.
4. Multiply X4 with Z4.
5. Bitwise XOR the results of steps 1 and 3.
6. Bitwise XOR the results of steps 2 and 4.
7. Multiply the result of step 5 with Z5.
8. Add the results of steps 6 and 7.
9. Multiply the result of step 8 with Z6.
10. Add the results of steps 7 and 9.
11. Bitwise XOR the results of steps 1 and 9.
12. Bitwise XOR the results of steps 3 and 9.
13. Bitwise XOR the results of steps 2 and 10.
14. Bitwise XOR the results of steps 4 and 10.

Six subkeys are used in each of the eight rounds, and the final 4 subkeys are used in the ninth half-round final transformation.

Swapping occurs for every round until the final complete round (round 8). After eight complete rounds, the final half-round transformation occurs. The steps involved are the following:

1. Multiply X1 with the first subkey.
2. Add X2 with the second subkey.
3. Add X3 with the third subkey.
4. Multiply X4 with the fourth subkey.

The concatenation of the four blocks is the encrypted output.

Decryption in IDEA

The decryption process uses the same steps as the encryption process. However, different 16-bit key subblocks are generated. Each of the 52 16-bit key subblocks used for decryption is the inverse of the key subblock used during encryption with respect to applied algebraic operations.

Also, these subblocks are used in reverse order during decryption. Decryption in IDEA works on the shoes and socks principle, i.e., the last encryption is the first to be removed.

=====

Unit-IV

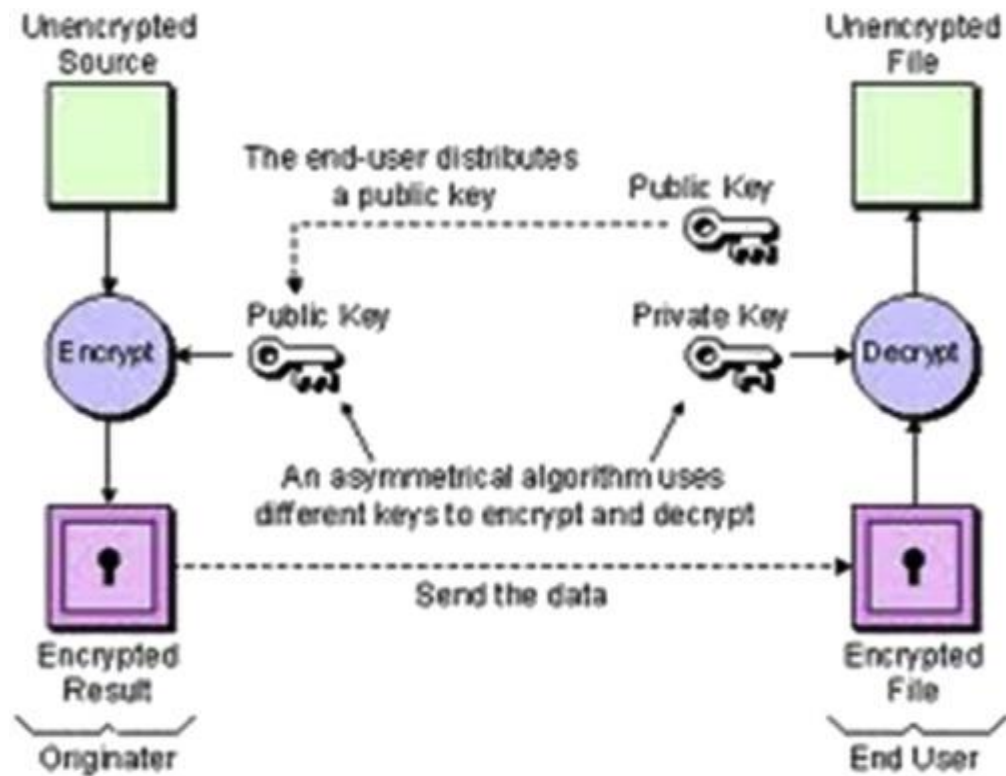
Asymmetric Key Cryptography

1. Asymmetric Key Algorithm:

Asymmetric cryptography is a second form of cryptography. Asymmetric cryptography is scalable for use in very large and ever-expanding environments where data are frequently exchanged between different communication partners. With asymmetric cryptography:

- Each user has two keys: a public key and a private key.
- Both keys are mathematically related (both keys together are called the key pair).
- The public key is made available to anyone. The private key is kept secret.
- Both keys are required to perform an operation. For example, data encrypted with the private key is unencrypted with the public key. Data encrypted with the public key is unencrypted with the private key.
- Encrypting data with the private key creates a digital signature. This ensures the message has come from the stated sender (because only the sender had access to the private key to be able to create the signature).
- A digital envelope is signing a message with a recipient's public key. A digital envelope, which serves as a means of access control by ensuring that only the intended recipient can open the message (because only the receiver will have the private key necessary to unlock the envelope; this is also known as receiver authentication).
- If the private key is ever discovered, a new key pair must be generated.

Asymmetric cryptography is often used to exchange the secret key to prepare for using symmetric cryptography to encrypt data. In the case of a key exchange, one party creates the secret key and encrypts it with the public key of the recipient. The recipient would then decrypt it with their private key. The remaining communication would be done with the secret key being the encryption key. Asymmetric encryption is used in key exchange, email security, Web security, and other encryption systems that require key exchange over the public network.



Pros:

- Key management
- Two keys (public and private), private key cannot be derived for the public, so the public key can be freely distributed without confidentially being compromised.
- Offers: Digital signatures, integrity checks, and nonrepudiation.

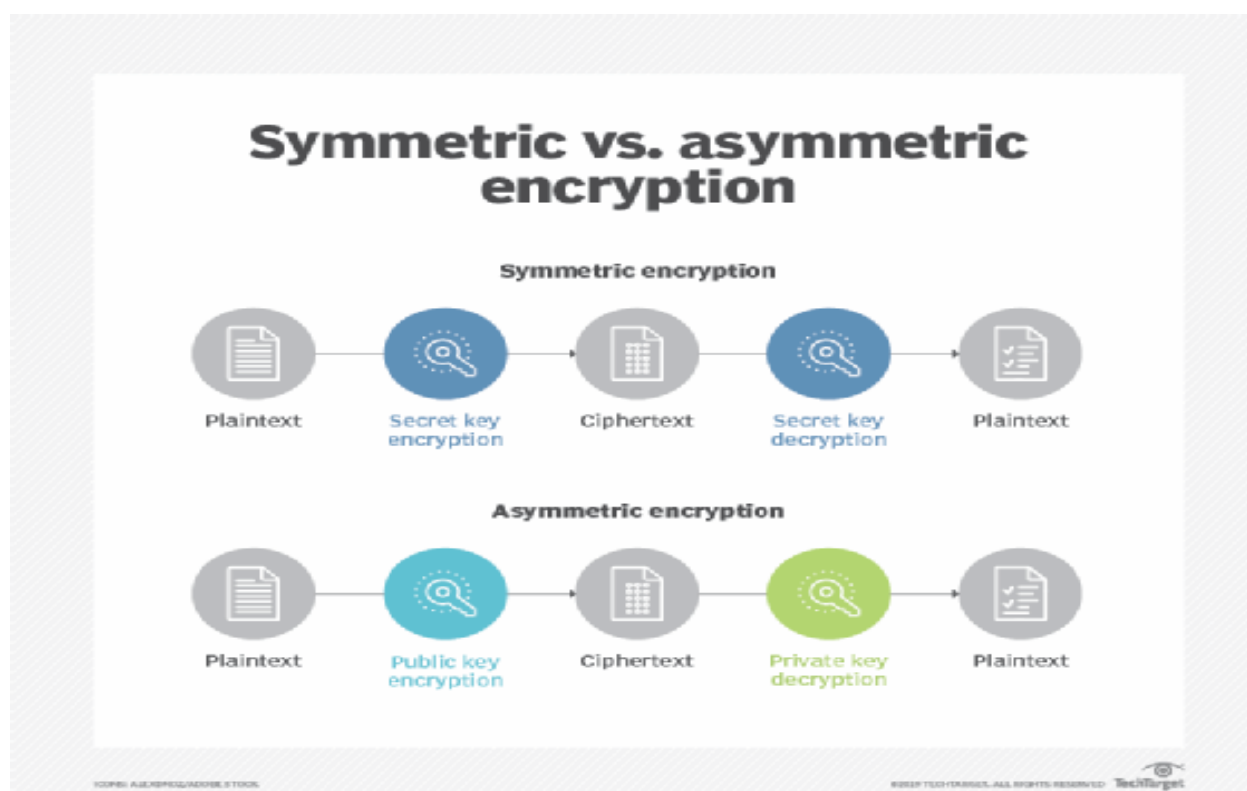
Cons:

- Speed/file size
- Because symmetric-key algorithms are generally much less computationally intensive than asymmetric key algorithms.
- In practice, asymmetric key algorithm are typically hundreds to thousands of times slower than a symmetric key algorithm.

2. Difference Between Symmetric and Asymmetric Encryption

- Symmetric encryption uses a single key that needs to be shared among the people who need to receive the message while asymmetric encryption uses a pair of public keys and a private key to encrypt and decrypt messages when communicating.
- Symmetric encryption is an old technique while asymmetric encryption is relatively new.
- Asymmetric encryption was introduced to complement the inherent problem of the need to share the key in symmetric encryption model, eliminating the need to share the key by using a pair of public-private keys.
- Asymmetric encryption takes relatively more time than the symmetric encryption.

Key Differences	Symmetric Encryption	Asymmetric Encryption
Size of cipher text	Smaller cipher text compares to original plain text file.	Larger cipher text compares to original plain text file.
Data size	Used to transmit big data.	Used to transmit small data.
Resource Utilization	Symmetric key encryption works on low usage of resources.	Asymmetric encryption requires high consumption of resources.
Key Lengths	128 or 256-bit key size.	RSA 2048-bit or higher key size.
Security	Less secured due to use a single key for encryption.	Much safer as two keys are involved in encryption and decryption.
Number of keys	Symmetric Encryption uses a single key for encryption and decryption.	Asymmetric Encryption uses two keys for encryption and decryption
Techniques	It is an old technique.	It is a modern encryption technique.
Confidentiality	A single key for encryption and decryption has chances of key compromised.	Two keys separately made for encryption and decryption that removes the need to share a key.
Speed	Symmetric encryption is fast technique	Asymmetric encryption is slower in terms of speed.
Algorithms	RC4, AES, DES, 3DES, and QUAD.	RSA, Diffie-Hellman, ECC algorithms.



3. RSA Algorithm:

The RSA algorithm (Rivest-Shamir-Adleman) is the basis of a cryptosystem - a suite of cryptographic algorithms that are used for specific security services or purposes - which enables public key encryption and is widely used to secure sensitive data, particularly when it is being sent over an insecure network such as the internet.

RSA was first publicly described in 1977 by Ron Rivest, Adi Shamir and Leonard Adleman of the Massachusetts Institute of Technology, though the 1973 creation of a public key algorithm by British mathematician Clifford Cocks was kept classified by the U.K.'s GCHQ until 1997.

Public key cryptography, also known as asymmetric cryptography, uses two different but mathematically linked keys -- one public and one private. The public key can be shared with everyone, whereas the private key must be kept secret.

RSA is a type of asymmetric encryption, which uses two different but linked keys.

In RSA cryptography, both the public and the private keys can encrypt a message. The opposite key from the one used to encrypt a message is used to decrypt it. This attribute is one reason why RSA has become the most widely used asymmetric algorithm: It provides a method to assure the confidentiality, integrity, authenticity, and non-repudiation of electronic communications and data storage.

Many protocols, including Secure Shell (SSH), OpenPGP, S/MIME, and SSL/TLS, rely on RSA for encryption and digital signature functions. It is also used in software programs -- browsers are an obvious example, as they need to establish a secure connection over an insecure network, like the internet, or validate a digital signature. RSA signature verification is one of the most commonly performed operations in network-connected systems.

Why is the RSA algorithm used?

RSA derives its security from the difficulty of factoring large integers that are the product of two large prime numbers. Multiplying these two numbers is easy, but determining the original prime numbers from the total -- or factoring -- is considered infeasible due to the time it would take using even today's supercomputers.

The public and private key generation algorithm is the most complex part of RSA cryptography. Two large prime numbers, p and q , are generated using the Rabin-Miller primality test algorithm. A modulus, n , is calculated by multiplying p and q . This number is

used by both the public and private keys and provides the link between them. Its length, usually expressed in bits, is called the key length.

The public key consists of the modulus n and a public exponent, e , which is normally set at 65537, as it's a prime number that is not too large. The e figure doesn't have to be a secretly selected prime number, as the public key is shared with everyone.

The private key consists of the modulus n and the private exponent d , which is calculated using the Extended Euclidean algorithm to find the multiplicative inverse with respect to the totient of n .

How does the RSA algorithm work?

Alice generates her RSA keys by selecting two primes: $p=11$ and $q=13$. The modulus is $n=p \times q=143$. The totient is $\phi(n)=(p-1) \times (q-1)=120$. She chooses 7 for her RSA public key e and calculates her RSA private key using the Extended Euclidean algorithm, which gives her 103.

Bob wants to send Alice an encrypted message, M , so he obtains her RSA public key (n, e) which, in this example, is $(143, 7)$. His plaintext message is just the number 9 and is encrypted into ciphertext, C , as follows:

$$M^e \bmod n = 9^7 \bmod 143 = 48 = C$$

When Alice receives Bob's message, she decrypts it by using her RSA private key (d, n) as follows:

$$C^d \bmod n = 48^{103} \bmod 143 = 9 = M$$

To use RSA keys to digitally sign a message, Alice would need to create a hash -- a message digest of her message to Bob -- encrypt the hash value with her RSA private key, and add the key to the message. Bob can then verify that the message has been sent by Alice and has not been altered by decrypting the hash value with her public key. If this value matches the hash of the original message, then only Alice could have sent it -- authentication and non-repudiation -- and the message is exactly as she wrote it -- integrity.

Alice could, of course, encrypt her message with Bob's RSA public key -- confidentiality -- before sending it to Bob. A digital certificate contains information that identifies the certificate's owner and also contains the owner's public key. Certificates are signed by

the certificate authority that issues them, and they can simplify the process of obtaining public keys and verifying the owner.

4. Diffie-Hellman Key Exchange:

The algorithm is based on Elliptic Curve Cryptography, a method of doing public-key cryptography based on the algebra structure of elliptic curves over finite fields. The DH also uses the trapdoor function, just like many other ways to do public-key cryptography. The simple idea of understanding to the DH Algorithm is the following.

1. The first party picks two prime numbers, g and p and tells them to the second party.
2. The second party then picks a secret number (let's call it a), and then it computes $g^a \bmod p$ and sends the result back to the first party; let's call the result A . Keep in mind that the secret number is not sent to anyone, only the result is.
3. Then the first party does the same; it selects a secret number b and calculates the result B similar to the
4. step 2. Then, this result is sent to the second party.
5. The second party takes the received number B and calculates $B^a \bmod p$
6. The first party takes the received number A and calculates $A^b \bmod p$

This is where it gets interesting; the answer in step 5 is the same as the answer in step 4. This means both parties will get the same answer no matter the order of exponentiation.

$$(g^a \bmod p)^b \bmod p = g^{ab} \bmod p$$
$$(g^b \bmod p)^a \bmod p = g^{ba} \bmod p$$

The number we came within steps 4 and 5 will be taken as the shared secret key. This key can be used to do any encryption of data that will be transmitted, such as blowfish, AES, etc.

Diffie Hellman Algorithm

1. $\text{key} = (Y_A)^{X_B} \bmod q$ -> this is the same as calculated by B

2. Global Public Elements

- q : q is a prime number
- a : $a < q$ and a is the primitive root of q

3. Key generation for user A

- Select a Private key X_A Here, $X_A < q$

Now, Calculation of Public key Y_A $Y_A = a^{X_A} \bmod q$

4. Key generation for user B

- Select a Private key X_B Here, $X_B < q$
- Now, Calculation of Public key Y_B $Y_B = a^{X_B} \bmod q$

5. Calculation of Secret Key by A

- $\text{key} = (Y_B)^{X_A} \bmod q$

6. Calculation of Secret Key by B

- $\text{key} = (Y_A)^{X_B} \bmod q$

Example

1. Alice and Bob both use public numbers $P = 23$, $G = 5$

2. Alice selected private key $a = 4$, and Bob selected $b = 3$ as the private key

3. Both Alice and Bob now calculate the value of x and y as follows:

- Alice: $x = (5^4 \bmod 23) = 4$
- Bob: $y = (5^3 \bmod 23) = 10$

4. Now, both Alice and Bob exchange public numbers with each other.

5. Alice and Bob now calculate the symmetric keys

- Alice: $k_a = y^a \bmod p = 10^4 \bmod 23 = 18$
- Bob: $k_b = x^b \bmod p = 4^3 \bmod 23 = 18$

6. 18 is the shared secret key.

Uses of Diffie Hellman Algorithm

Aside from using the algorithm for generating public keys, there are some other places where DH Algorithm can be used:

- **Encryption:** The Diffie Hellman key exchange algorithm can be used to encrypt; one of the first schemes to do is ElGamal encryption. One modern example of it is called Integrated Encryption Scheme, which provides security against chosen plain text and chosen clipboard attacks.
- **Password Authenticated Agreement:** When two parties share a password, a password-authenticated key agreement can be used to prevent the Man in the middle attack. This key Agreement can be in the form of Diffie-Hellman. Secure Remote Password Protocol is a good example that is based on this technique.
- **Forward Secrecy:** Forward secrecy-based protocols can generate new key pairs for each new session, and they can automatically discard them when the session is finished. In these forward Secrecy protocols, more often than not, the Diffie Hellman key exchange is used.

Advantages of the Diffie Hellman Algorithm

- The sender and receiver don't need any prior knowledge of each other.
- Once the keys are exchanged, the communication of data can be done through an insecure channel.
- The sharing of the secret key is safe.

Disadvantages of the Diffie Hellman Algorithm

- The algorithm cannot be used for any asymmetric key exchange.
- Similarly, it cannot be used for signing digital signatures.
- Since it doesn't authenticate any party in the transmission, the Diffie Hellman key exchange is susceptible to a man-in-the-middle attack.

5. Digital Signature

What is a digital signature?

A digital signature—a type of electronic signature—is a mathematical algorithm routinely used to validate the authenticity and integrity of a message (e.g., an email, a credit card transaction, or a digital document). Digital signatures create a virtual fingerprint that is unique to a person or entity and are used to identify users and protect information in digital messages or documents. In emails, the email content itself becomes part of the digital signature. Digital signatures are significantly more secure than other forms of electronic signatures.

Why would you use a digital signature?

Digital signatures increase the transparency of online interactions and develop trust between customers, business partners, and vendors.

How do digital signatures work?

Familiarize yourself with the following terms to better understand how digital signatures work:

- **Hash function** – A hash function (also called a “hash”) is a fixed-length string of numbers and letters generated from a mathematical algorithm and an arbitrarily sized file such as an email, document, picture, or other type of data. This generated string is unique to the file being hashed and is a one-way function— a computed hash cannot be reversed to find other files that may generate the same hash value. Some of the more popular hashing algorithms in use today are Secure Hash Algorithm-1 (SHA-1), the Secure Hashing Algorithm-2 family (SHA-2 and SHA-256), and Message Digest 5 (MD5).
- **Public key cryptography** – Public key cryptography (also known as asymmetric encryption) is a cryptographic method that uses a key pair system. One key, called the public key, encrypts the data. The other key, called the private key, decrypts the data. Public key cryptography can be used several ways to ensure confidentiality, integrity, and authenticity. Public key cryptography can
 - Ensure integrity by creating a digital signature of the message using the sender’s private key. This is done by hashing the message and encrypting the hash value with their private key. By doing this, any changes to the message will result in a different hash value.
 - Ensure confidentiality by encrypting the entire message with the recipient’s public key. This means that only the recipient, who is in possession of the corresponding private key, can read the message.
 - Verify the user’s identity using the public key and checking it against a certificate authority.
- **Public key infrastructure (PKI)** – PKI consists of the policies, standards, people, and systems that support the distribution of public keys and the identity validation of individuals or entities with digital certificates and a certificate authority.
- **Certificate authority (CA)** – A CA is a trusted third party that validates a person’s identity and either generates a public/private key pair on their behalf or associates an existing public key provided by the person to that person. Once a CA validates

someone's identity, they issue a digital certificate that is digitally signed by the CA. The digital certificate can then be used to verify a person associated with a public key when requested.

- **Digital certificates** – Digital certificates are analogous to driver licenses in that their purpose is to identify the holder of a certificate. Digital certificates contain the public key of the individual or organization and are digitally signed by a CA. Other information about the organization, individual, and CA can be included in the certificate as well.
- **Pretty Good Privacy (PGP)/OpenPGP** – PGP/OpenPGP is an alternative to PKI. With PGP/OpenPGP, users “trust” other users by signing certificates of people with verifiable identities. The more interconnected these signatures are, the higher the likelihood of verifying a particular user on the internet. This concept is called the “Web of Trust.”

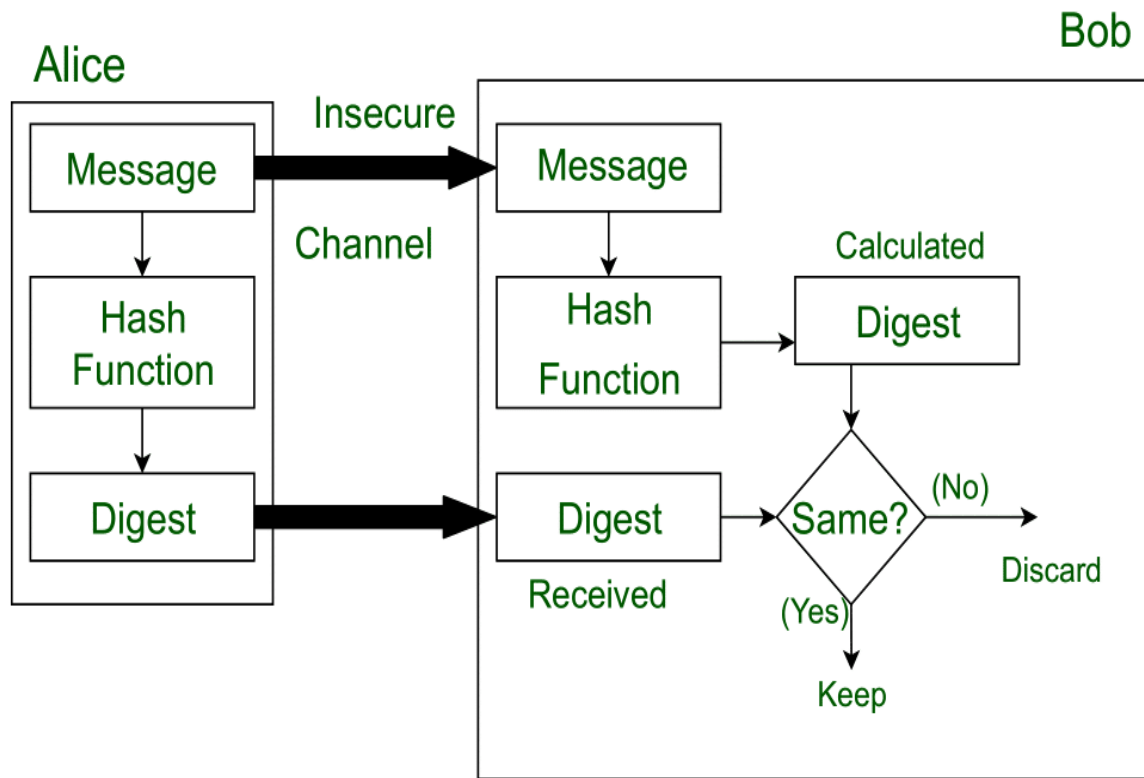
Digital signatures work by proving that a digital message or document was not modified—intentionally or unintentionally—from the time it was signed. Digital signatures do this by generating a unique hash of the message or document and encrypting it using the sender's private key. The hash generated is unique to the message or document, and changing any part of it will completely change the hash.

Once completed, the message or digital document is digitally signed and sent to the recipient. The recipient then generates their own hash of the message or digital document and decrypts the sender's hash (included in the original message) using the sender's public key. The recipient compares the hash they generate against the sender's decrypted hash; if they match, the message or digital document has not been modified and the sender is authenticated.

6. Basic concepts of Message Digest and Hash Function.

Message Digest is used to ensure the integrity of a message transmitted over an insecure channel (where the content of the message can be changed). The message is passed through a Cryptographic hash function. This function creates a compressed image of the message called **Digest**.

Lets assume, Alice sent a message and digest pair to Bob. To check the integrity of the message Bob runs the cryptographic hash function on the received message and gets a new digest. Now, Bob will compare the new digest and the digest sent by Alice. If, both are same then Bob is sure that the original message is not changed.



This message and digest pair is equivalent to a physical document and fingerprint of a person on that document. Unlike the physical document and the fingerprint, the message and the digest can be sent separately.

- Most importantly, the digest should be unchanged during the transmission.
- The cryptographic hash function is a one way function, that is, a function which is practically infeasible to invert. This cryptographic hash function takes a message of variable length as input and creates a **digest / hash / fingerprint** of fixed length, which is used to verify the integrity of the message.
- Message digest ensures the integrity of the document. To provide authenticity of the message, digest is encrypted with sender's private key. Now this digest is called digital signature, which can be only decrypted by the receiver who has sender's public key. Now the receiver can authenticate the sender and also verify the integrity of the sent message.

Example:

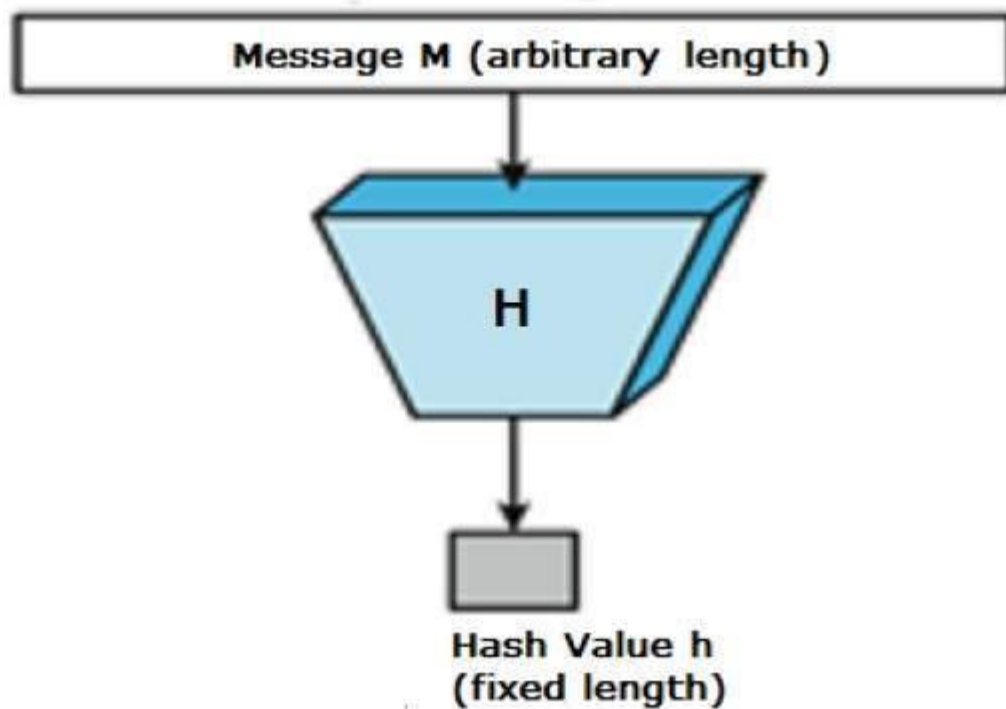
The hash algorithm MD5 is widely used to check the integrity of messages. MD5 divides the message into blocks of 512 bits and creates a 128 bit digest (typically, 32 Hexadecimal digits). It is no longer considered reliable for use as researchers have demonstrated techniques capable of easily generating MD5 collisions on commercial computers. The weaknesses of MD5 have been exploited by the Flame malware in 2012.

In response to the insecurities of MD5 hash algorithms, the Secure Hash Algorithm (SHA) was invented.

Hash functions are extremely useful and appear in almost all information security applications.

A hash function is a mathematical function that converts a numerical input value into another compressed numerical value. The input to the hash function is of arbitrary length but output is always of fixed length.

Values returned by a hash function are called **message digest** or simply **hash values**. The following picture illustrated hash function –



Features of Hash Functions

The typical features of hash functions are –

- **Fixed Length Output (Hash Value)**
 - Hash function converts data of arbitrary length to a fixed length. This process is often referred to as **hashing the data**.
 - In general, the hash is much smaller than the input data, hence hash functions are sometimes called **compression functions**.
 - Since a hash is a smaller representation of a larger data, it is also referred to as a **digest**.
 - Hash function with n bit output is referred to as an **n -bit hash function**. Popular hash functions generate values between 160 and 512 bits.
- **Efficiency of Operation**
 - Generally for any hash function h with input x , computation of $h(x)$ is a fast operation.
 - Computationally hash functions are much faster than a symmetric encryption.

7. Man in Middle Attack,

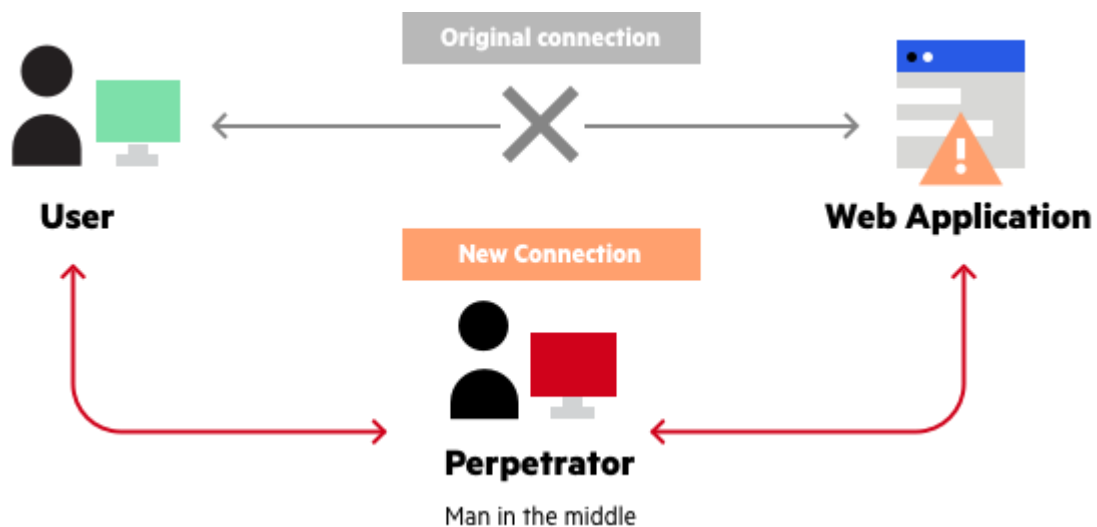
A man in the middle (MITM) attack is a general term for when a perpetrator positions himself in a conversation between a user and an application—either to eavesdrop or to impersonate one of the parties, making it appear as if a normal exchange of information is underway.

The goal of an attack is to steal personal information, such as login credentials, account details and credit card numbers. Targets are typically the users of financial applications, SaaS businesses, e-commerce sites and other websites where logging in is required.

Information obtained during an attack could be used for many purposes, including identity theft, unapproved fund transfers or an illicit password change.

Additionally, it can be used to gain a foothold inside a secured perimeter during the infiltration stage of an advanced persistent threat (APT) assault.

Broadly speaking, a MITM attack is the equivalent of a mailman opening your bank statement, writing down your account details and then resealing the envelope and delivering it to your door.



Man in the middle attack example

MITM attack progression

Successful MITM execution has two distinct phases: interception and decryption.

Interception

The first step intercepts user traffic through the attacker's network before it reaches its intended destination.

The most common (and simplest) way of doing this is a passive attack in which an attacker makes free, malicious WiFi hotspots available to the public. Typically named in a way that corresponds to their location, they aren't password protected. Once a victim connects to such a hotspot, the attacker gains full visibility to any online data exchange.

Attackers wishing to take a more active approach to interception may launch one of the following attacks:

- **IP spoofing** involves an attacker disguising himself as an application by altering packet headers in an IP address. As a result, users attempting to access a URL connected to the application are sent to the attacker's website.
- **ARP spoofing** is the process of linking an attacker's MAC address with the IP address of a legitimate user on a local area network using fake ARP messages. As a result, data sent by the user to the host IP address is instead transmitted to the attacker.
- **DNS spoofing**, also known as DNS cache poisoning, involves infiltrating a DNS server and altering a website's address record. As a result, users attempting to access the site are sent by the altered DNS record to the attacker's site.

Decryption

After interception, any two-way SSL traffic needs to be decrypted without alerting the user or application. A number of methods exist to achieve this:

- **HTTPS spoofing** sends a phony certificate to the victim's browser once the initial connection request to a secure site is made. It holds a digital thumbprint associated with the compromised application, which the browser verifies according to an existing list of trusted sites. The attacker is then able to access any data entered by the victim before it's passed to the application.
- **SSL BEAST** (browser exploit against SSL/TLS) targets a TLS version 1.0 vulnerability in SSL. Here, the victim's computer is infected with malicious JavaScript that intercepts encrypted cookies sent by a web application. Then the app's cipher block chaining (CBC) is compromised so as to decrypt its cookies and authentication tokens.
- **SSL hijacking** occurs when an attacker passes forged authentication keys to both the user and application during a TCP handshake. This sets up what appears to be a secure connection when, in fact, the man in the middle controls the entire session.
- **SSL stripping** downgrades a HTTPS connection to HTTP by intercepting the TLS authentication sent from the application to the user. The attacker sends an unencrypted version of the application's site to the user while maintaining the secured session with the application. Meanwhile, the user's entire session is visible to the attacker.

Man in the middle attack prevention

Blocking MITM attacks requires several practical steps on the part of users, as well as a combination of encryption and verification methods for applications.

For users, this means:

- Avoiding WiFi connections that aren't password protected.
- Paying attention to browser notifications reporting a website as being unsecured.
- Immediately logging out of a secure application when it's not in use.
- Not using public networks (e.g., coffee shops, hotels) when conducting sensitive transactions.

For website operators, secure communication protocols, including TLS and HTTPS, help mitigate spoofing attacks by robustly encrypting and authenticating transmitted data. Doing so prevents the interception of site traffic and blocks the decryption of sensitive data, such as authentication tokens.

It is considered best practice for applications to use SSL/TLS to secure every page of their site and not just the pages that require users to log in. Doing so helps decrease the chance of an attacker stealing session cookies from a user browsing on an unsecured section of a website while logged in.'

See how Imperva Web Application Firewall can help you with MITM attacks.

Using Imperva to protect against MITM

MITM attacks often occur due to suboptimal SSL/TLS implementations, like the ones that enable the SSL BEAST exploit or supporting the use of outdated and under-secured ciphers.

To counter these, Imperva provides its customer with an optimized end-to-end SSL/TLS encryption, as part of its suite of security services.

Hosted on Imperva content delivery network (CDN), the certificates are optimally implemented to prevent SSL/TLS compromising attacks, such as downgrade attacks (e.g. SSL stripping), and to ensure compliancy with latest PCI DSS demands.

Offered as a managed service, SSL/TLS configuration is kept up to date maintained by a professional security, both to keep up with compliancy demands and to counter emerging threats (e.g. Heartbleed).

Finally, with the Imperva cloud dashboard, customer can also configure HTTP Strict Transport Security (HSTS) policies to enforce the use SSL/TLS security across multiple

subdomains. This helps further secure website and web application from protocol downgrade attacks and cookie hijacking attempts.

8. DoS and DDoS Attacks.

DOS Attack is a denial-of-service attack, in this attack a computer sends a massive amount of traffic to a victim's computer and shuts it down. Dos attack is an online attack that is used to make the website unavailable for its users when done on a website. This attack makes the server of a website that is connected to the internet by sending a large number of traffic to it.

2. DDOS Attack means distributed denial of service in this attack dos attacks are done from many different locations using many systems.

Difference between DOS and DDOS attacks:

DOS	DDOS
DOS Stands for Denial of service attack.	DDOS Stands for Distributed Denial of service attack.
In Dos attack single system targets the victim system.	In DDoS multiple systems attacks the victims system.
Victim PC is loaded from the packet of data sent from a single location.	Victim PC is loaded from the packet of data sent from Multiple location.
Dos attack is slower as compared to DDoS.	DDoS attack is faster than Dos Attack.
Can be blocked easily as only one system is used.	It is difficult to block this attack as multiple devices are sending packets and attacking from multiple locations.
In DOS Attack only single device is used with DOS Attack tools.	In DDoS attack, The volume Bots are used to attack at the same time.
DOS Attacks are Easy to trace.	DDOS Attacks are Difficult to trace.
Volume of traffic in the Dos attack is less as compared to DDos.	DDoS attacks allow the attacker to send massive volumes of traffic to the victim network.

DOS	DDOS
Types of DOS Attacks are: 1. Buffer overflow attacks 2. Ping of Death or ICMP flood 3. Teardrop Attack 4. Flooding Attack	Types of DDOS Attacks are: 1. Volumetric Attacks 2. Fragmentation Attacks 3. Application Layer Attacks 4. Protocol Attack.

=====

UNIT: V

Internet Security Protocols

1. User Authentication Basic Concepts

User authentication verifies the identity of a user attempting to gain access to a network or computing resource by authorizing a human-to-machine transfer of credentials during interactions on a network to confirm a user's authenticity. The term contrasts with machine authentication, which is an automated authentication method that does not require user input.

Authentication helps ensure only authorized users can gain access to a system by preventing unauthorized users from gaining access and potentially damaging systems, stealing information or causing other problems. Almost all human-to-computer interactions other than guest and automatically logged-in accounts -- perform a user authentication. It authorizes access on both wired and wireless networks to enable access to networked and internet-connected systems and resources.

A straightforward process, user authentication consists of three tasks:

1. **Identification.** Users have to prove who they are.
2. **Authentication.** Users have to prove they are who they say they are.
3. **Authorization.** Users have to prove they're allowed to do what they are trying to do.

User authentication can be as simple as requiring a user to type a unique identifier, such as a user ID, along with a password to access a system. It can also be more complex, however -- for example, requiring a user to provide information about physical objects or the environment or even take actions, such as placing a finger on a fingerprint reader.

User authentication methods

The main factors used in user authentication include the following:

- **Knowledge factors** include all things users must know in order to log in to gain access to a system. Usernames, IDs, passwords and personal identification numbers (PINs) all fall under this category.

- **Possession factors** consist of anything users must have in their possession in order to log in. This category includes one-time password tokens, key fobs, smartphone apps, and employee ID cards.
- **Inherence factors** include characteristics inherent to individuals that confirm their identity. This category includes the scope of biometrics, such as retina scans, fingerprint scans, facial recognition and Voice authentication.

Different types of Authentications:

When it comes to authentication and security, there is a vast ocean of different authentication options to choose from. Before adopting or choosing any of the authentication methods for your organization's employees or end-users, you should be aware of a few key factors that will help you choose the most appropriate authentication technique for you:

1. Security capability of that Authentication Method
2. Usability interface

Let's take a closer look at the many sorts of authentication techniques available:

a. Password Based Login:

The most commonly utilized regular login authentication system that you will employ on a daily basis while utilizing an online service is password-based login. You need to input a combination of your username/mobile number and a password when using the Password-Based Authentication technique. The individual is authorized only when both of these elements have been verified. However, because today's customers use multiple online services (apps and websites), it's tough to keep track of all of their usernames and passwords. As a result of this, end-users engage in unethical behaviors such as forgetting passwords, using the same password for several services, and so on. Cybercriminals enter at this point and begin actions such as phishing, data breaches, and so on. That is the fundamental reason why standard password-based authentication is losing favor and more organizations are turning to advanced additional security authentication factors.

b. Multi-Factor Authentication:

Multi-Factor Authentication (MFA) is an authentication method in which an individual must pass multiple factors in order to gain access to a service or network. It's an extra layer of security on top of the standard password-based login. Individuals must also submit a second factor in the form of a one-time code that they will receive through phone or email in addition to their Username and Password.

You may quickly configure several Multi-Factor Authentication (MFA) methods to give an extra layer of security to your resources. OTP/TOTP via SMS, OTP/TOTP over Email, Push notification, Hardware Token, and Mobile Authenticator are all examples of MFA methods (Google, Microsoft, Authy, etc). You can choose any of the MFA techniques and implement them for organizational security based on your needs and

requirements. After traditional password-based login, Multi-Factor Authentication is the most trusted authentication mechanism. For improved security, password-based traditional authentication and Multi-Factor Authentication methods are usually used simultaneously.

c. Biometric Authentication:

Individual physical attributes such as fingerprints, palms, retinas, voice, face, and voice recognition are used in biometric authentication. Biometric authentication works in the following way: first, the physical characteristics of individuals are saved in a database. Individuals' physical features are checked against the data contained in the database whenever a user wants to access any device or physically enter any premises (Organization, School, Colleges, Workplace). Biometric authentication technology is mostly employed by private organizations, airports, and border crossing points where security is a top priority. Because of its capacity to create a high level of security and a user-friendly frictionless flow, biometrics is one of the most often used security technologies. Among the most common biometric authentication methods are:

Fingerprint: To enable access, fingerprint authentication matches the unique pattern of an individual's print. In some advanced Fingerprint authentication systems, the vascular structure of the finger is also sensed. Because it is one of the most user-friendly and accurate biometric systems, fingerprint authentication is currently the most common biometric technology for ordinary customers. Biometrics' popularity can be due to the fact that you use your mobile phones with fingerprints on a regular basis, as well as companies or institutions that use Fingerprint authentication.

Retina & Iris : Scanners shine a strong light into the eye and look for distinctive patterns in the colourful ring around the pupil of the eye in this biometric. After that, the scanned pattern is compared to data recorded in a database. When a person wears spectacles or contact lenses, eye-based authentication can be inaccurate.

Facial: In facial authentication, multiple aspects of an individual's face are scanned while they try to get access to a certain resource. When comparing faces from different angles or persons that look similar, such as family members, face recognition results can be inconsistent.

Voice Recognition: Your voice tone is stored with a standardized secret code in the same way that the above-mentioned approach does. A check occurs because you must speak off each time you want access.

d. Certificate-based authentication:

Certificate-based authentication identifies people, servers, workstations, and devices by using an electronic digital identity. In our daily lives, a digital certificate functions similarly to a driver's license or a passport. A certificate is made up of a user's digital identity, which contains a public key and a certification authority's digital signature.

This certificate verifies that the public key and the person who issued the certificate are both the same person. When a user attempts to log in to a server, they must first present their digital certificate. The server checks the digital certificate's identity and credibility by confirming that the user has a correctly associated private key with the certificate using cryptography.

e. **Token-Based Authentication:**

Token-Based Authentication allows users to enter their credentials only once and obtain a one-of-a-kind encrypted string exchange in return. After that, you won't have to input your credentials every time you want to log in or acquire access. The digital token ensures that you have already been granted access. Most use cases, such as Restful APIs that are accessed by many frameworks and clients, require token-based authentication.

2. **SSL protocol**

SSL, or Secure Sockets Layer, is an encryption-based Internet security protocol. It was first developed by Netscape in 1995 for the purpose of ensuring privacy, authentication, and data integrity in Internet communications. SSL is the predecessor to the modern TLS encryption used today.

A website that implements SSL/TLS has "HTTPS" in its URL instead of "HTTP."

How does SSL/TLS work?

- In order to provide a high degree of privacy, SSL encrypts data that is transmitted across the web. This means that anyone who tries to intercept this data will only see a garbled mix of characters that is nearly impossible to decrypt.
- SSL initiates an **authentication** process called a handshake between two communicating devices to ensure that both devices are really who they claim to be.
- SSL also digitally signs data in order to provide **data integrity**, verifying that the data is not tampered with before reaching its intended recipient.

There have been several iterations of SSL, each more secure than the last. In 1999 SSL was updated to become TLS.

Why is SSL/TLS important?

Originally, data on the Web was transmitted in plaintext that anyone could read if they intercepted the message. For example, if a consumer visited a shopping website, placed an

order, and entered their credit card number on the website, that credit card number would travel across the Internet unconcealed.

SSL was created to correct this problem and protect user privacy. By encrypting any data that goes between a user and a web server, SSL ensures that anyone who intercepts the data can only see a scrambled mess of characters. The consumer's credit card number is now safe, only visible to the shopping website where they entered it.

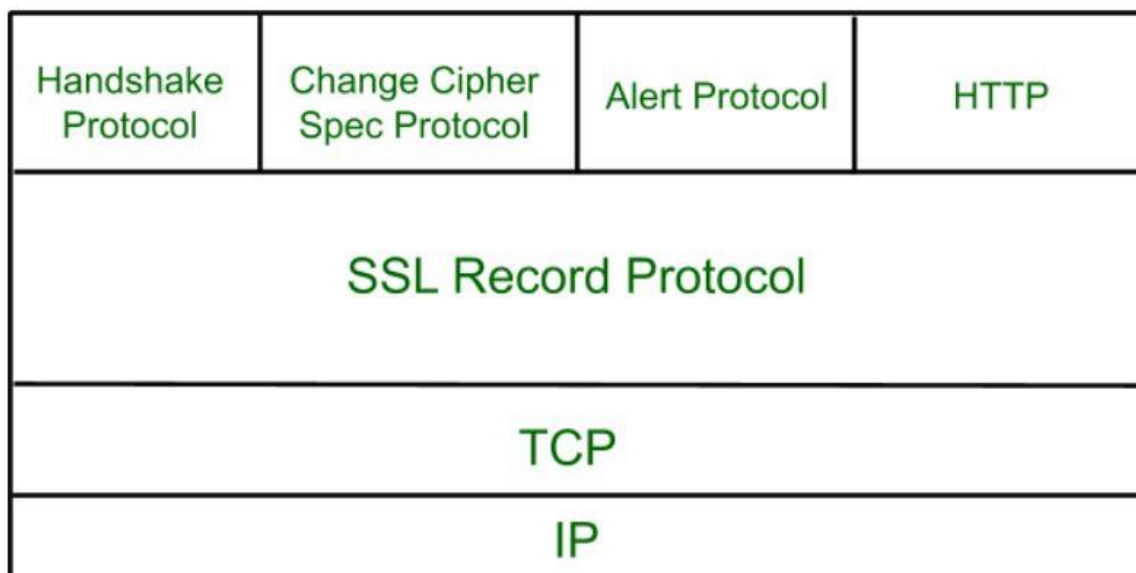
SSL also stops certain kinds of cyber-attacks: It authenticates web servers, which is important because attackers will often try to set up fake websites to trick users and steal data. It also prevents attackers from tampering with data in transit, like a tamper-proof seal on a medicine container.

Secure Socket Layer (SSL) provides security to the data that is transferred between web browser and server. SSL encrypts the link between a web server and a browser which ensures that all data passed between them remain private and free from attack.

Secure Socket Layer Protocols:

- SSL record protocol
- Handshake protocol
- Change-cipher spec protocol
- Alert protocol

SSL Protocol Stack:

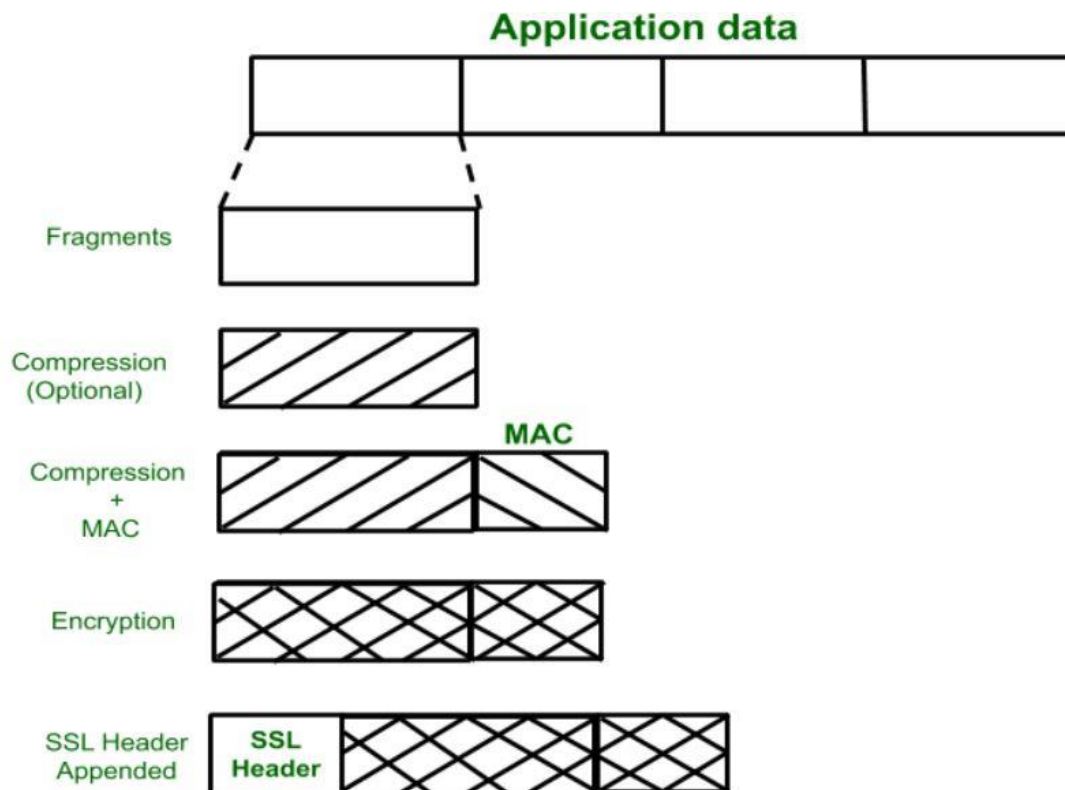


SSL Record Protocol:

SSL Record provides two services to SSL connection.

- Confidentiality
- Message Integrity

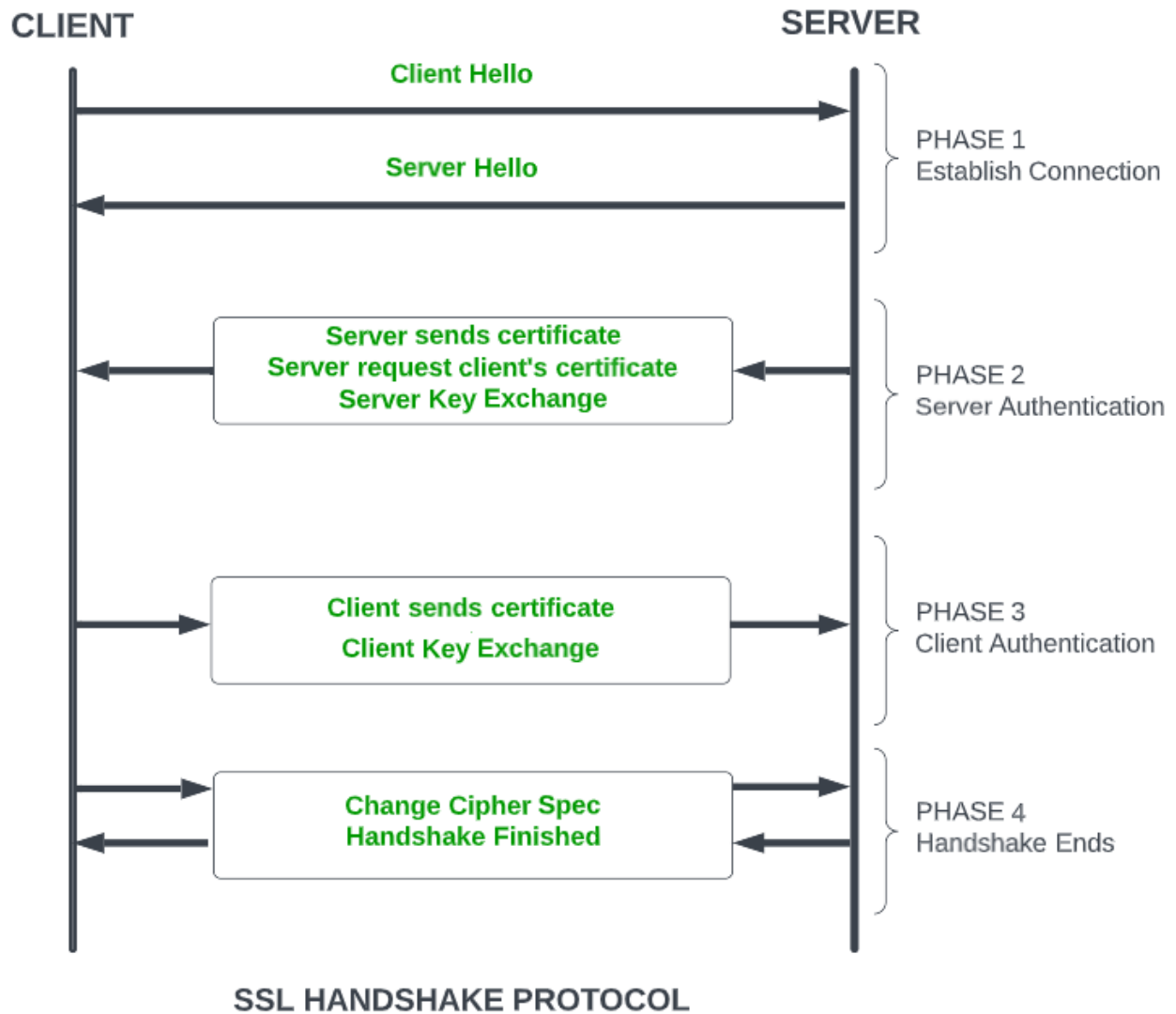
In the SSL Record Protocol application data is divided into fragments. The fragment is compressed and then encrypted MAC (Message Authentication Code) generated by algorithms like SHA (Secure Hash Protocol) and MD5 (Message Digest) is appended. After that encryption of the data is done and in last SSL header is appended to the data.



Handshake Protocol:

Handshake Protocol is used to establish sessions. This protocol allows the client and server to authenticate each other by sending a series of messages to each other. Handshake protocol uses four phases to complete its cycle.

- **Phase-1:** In Phase-1 both Client and Server send hello-packets to each other. In this IP session, cipher suite and protocol version are exchanged for security purposes.
- **Phase-2:** Server sends his certificate and Server-key-exchange. The server ends phase-2 by sending the Server-hello-end packet.
- **Phase-3:** In this phase, Client replies to the server by sending his certificate and Client-exchange-key.
- **Phase-4:** In Phase-4 Change-cipher suite occurred and after this Handshake Protocol ends.



SSL Handshake Protocol Phases diagrammatic representation

Change-cipher Protocol:

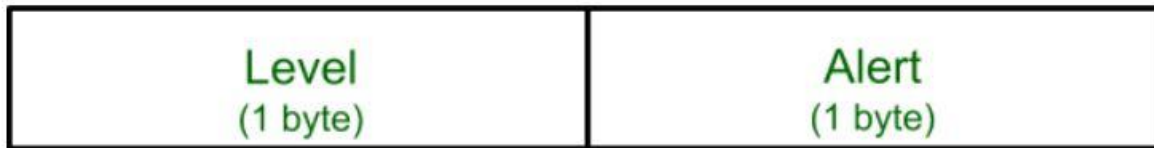
This protocol uses the SSL record protocol. Unless Handshake Protocol is completed, the SSL record Output will be in a pending state. After the handshake protocol, the Pending state is converted into the current state.

Change-cipher protocol consists of a single message which is 1 byte in length and can have only one value. This protocol's purpose is to cause the pending state to be copied into the current state.



Alert Protocol:

This protocol is used to convey SSL-related alerts to the peer entity. Each message in this protocol contains 2 bytes.



The level is further classified into two parts:

Warning (level = 1):

This Alert has no impact on the connection between sender and receiver. Some of them are:

Bad certificate: When the received certificate is corrupt.

No certificate: When an appropriate certificate is not available.

Certificate expired: When a certificate has expired.

Certificate unknown: When some other unspecified issue arose in processing the certificate, rendering it unacceptable.

Close notify: It notifies that the sender will no longer send any messages in the connection.

Fatal Error (level = 2):

This Alert breaks the connection between sender and receiver. The connection will be stopped, cannot be resumed but can be restarted. Some of them are :

Handshake failure: When the sender is unable to negotiate an acceptable set of security parameters given the options available.

Decompression failure: When the decompression function receives improper input.

Illegal parameters: When a field is out of range or inconsistent with other fields.

Bad record MAC: When an incorrect MAC was received.

Unexpected message: When an inappropriate message is received.

The second byte in the Alert protocol describes the error.

Silent Features of Secure Socket Layer:

- The advantage of this approach is that the service can be tailored to the specific needs of the given application.
- Secure Socket Layer was originated by Netscape.
- SSL is designed to make use of TCP to provide reliable end-to-end secure service.
- This is a two-layered protocol.

Versions of SSL:

SSL 1 – Never released due to high insecurity.

SSL 2 – Released in 1995.

SSL 3 – Released in 1996.

TLS 1.0 – Released in 1999.

TLS 1.1 – Released in 2006.

TLS 1.2 – Released in 2008.

TLS 1.3 – Released in 2018.

3. Steganography

Steganography is the technique of hiding secret data within an ordinary, non-secret, file or message in order to avoid detection; the secret data is then extracted at its destination. The use of steganography can be combined with encryption as an extra step for hiding or protecting data. The word steganography is derived from the Greek words steganos (meaning hidden or covered) and the Greek root graph (meaning to write).

Steganography can be used to conceal almost any type of digital content, including text, image, video or audio content; the data to be hidden can be hidden inside almost any other type of digital content. The content to be concealed through steganography -- called hidden text -- is often encrypted before being incorporated into the innocuous-seeming cover text file or data stream. If not encrypted, the hidden text is commonly processed in some way in order to increase the difficulty of detecting the secret content.

What are examples for steganography?

Steganography is practiced by those wishing to convey a secret message or code. While there are many legitimate uses for steganography, malware developers have also been found to use steganography to obscure the transmission of malicious code.

Forms of steganography have been used for centuries and include almost any technique for hiding a secret message in an otherwise harmless container. For example, using invisible ink to hide secret messages in otherwise inoffensive messages; hiding documents recorded on microdot -- which can be as small as 1 millimeter in diameter -- on or inside legitimate-seeming correspondence; and even by using multiplayer gaming environments to share information.

How is steganography used today?

In modern digital steganography, data is first encrypted or obfuscated in some other way and then inserted, using a special algorithm, into data that is part of a particular file format such as a JPEG image, audio or video file. The secret message can be embedded into ordinary data files in many different ways. One technique is to hide data in bits that represent the same color pixels repeated in a row in an image file. By applying the encrypted data to this redundant data in some inconspicuous way, the result will be an image file that appears identical to the original image but that has "noise" patterns of regular, unencrypted data.

The practice of adding a watermark -- a trademark or other identifying data hidden in multimedia or other content files -- is one common use of steganography. Watermarking is a technique often used by online publishers to identify the source of media files that have been found being shared without permission.

While there are many different uses of steganography, including embedding sensitive information into file types, one of the most common techniques is to embed a text file into an image file. When this is done, anyone viewing the image file should not be able to see a difference between the original image file and the encrypted file; this is accomplished by storing the message with less significant bites in the data file. This process can be completed manually or with the use of a steganography tool.

4. Basics of mail security,

Email security is the process of ensuring the availability, integrity and authenticity of email communications by protecting against the risk of email threats.

Email enables billions of connected people and organizations to communicate with one another to send messages. Email is at the foundation of how the internet is used, and it has long been a target for attacks.

Since the earliest days of email, it has been abused and misused in different ways with no shortage of email threats. Abuse of email includes the following:

- phishing attempts
- spoofing

- spam phishing
- malware delivery
- business email compromise (BEC)
- denial of service (DoS) attacks

Email security aims to help prevent attacks and abuse of email communication systems. Within the domain of email security, there are various email security protocols that technology standards organizations have proposed and recommended for implementation to help limit email risks. Protocols can be implemented by email clients and email servers, such as Microsoft Exchange and Microsoft 365, to help ensure the secure transit of email. Looking beyond just protocols, secure email gateways can help organizations and individuals to protect email from various threats.

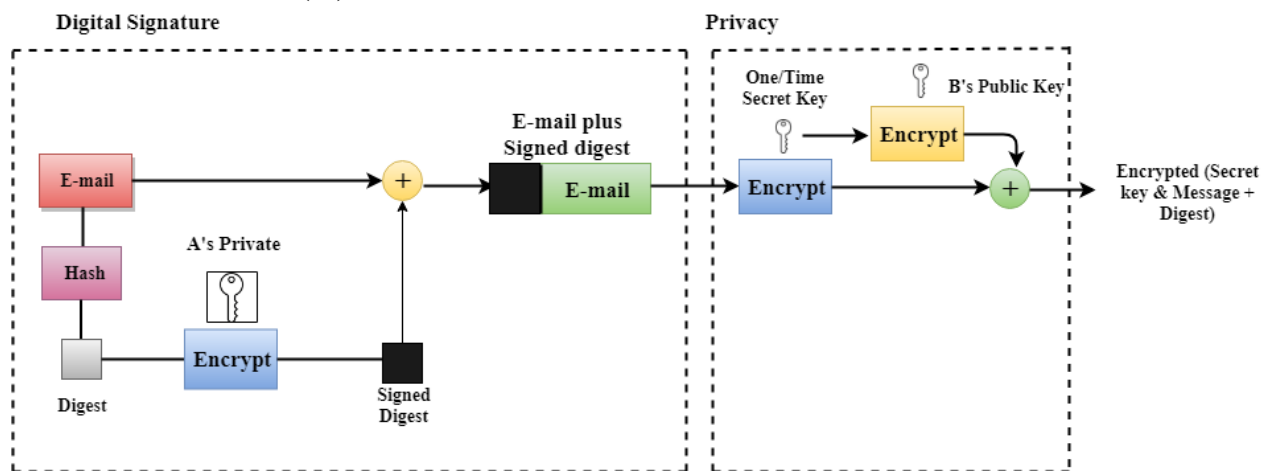
5. Pretty Good Privacy

- PGP stands for Pretty Good Privacy (PGP) which is invented by Phil Zimmermann.
- PGP was designed to provide all four aspects of security, i.e., privacy, integrity, authentication, and non-repudiation in the sending of email.
- PGP uses a digital signature (a combination of hashing and public key encryption) to provide integrity, authentication, and non-repudiation. PGP uses a combination of secret key encryption and public key encryption to provide privacy. Therefore, we can say that the digital signature uses one hash function, one secret key, and two private-public key pairs.
- PGP is an open source and freely available software package for email security.
- PGP provides authentication through the use of Digital Signature.
- It provides confidentiality through the use of symmetric block encryption.
- It provides compression by using the ZIP algorithm, and EMAIL compatibility using the radix-64 encoding scheme.

Following are the steps taken by PGP to create secure e-mail at the sender site:

- The e-mail message is hashed by using a hashing function to create a digest.
- The digest is then encrypted to form a signed digest by using the sender's private key, and then signed digest is added to the original email message.
- The original message and signed digest are encrypted by using a one-time secret key created by the sender.
- The secret key is encrypted by using a receiver's public key.
- Both the encrypted secret key and the encrypted combination of message and digest are sent together.

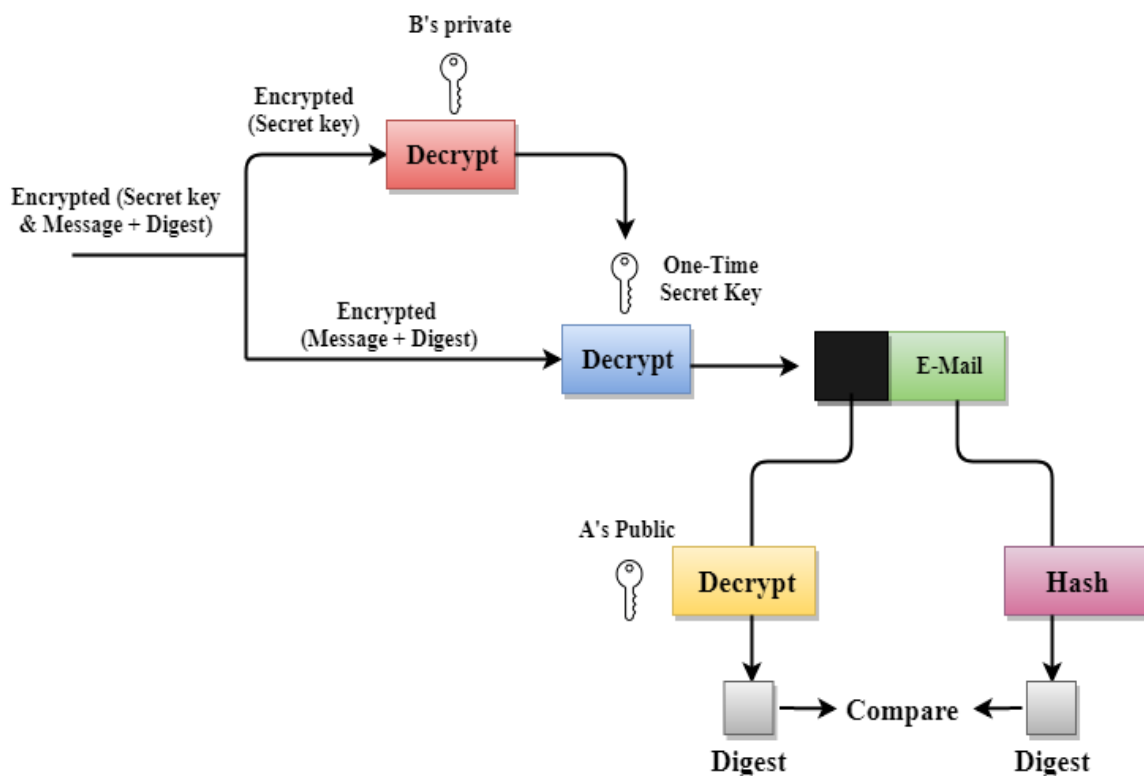
PGP at the Sender site (A)



Following are the steps taken to show how PGP uses hashing and a combination of three keys to generate the original message:

- The receiver receives the combination of encrypted secret key and message digest is received.
- The encrypted secret key is decrypted by using the receiver's private key to get the one-time secret key.
- The secret key is then used to decrypt the combination of message and digest.
- The digest is decrypted by using the sender's public key, and the original message is hashed by using a hash function to create a digest.
- Both the digests are compared if both of them are equal means that all the aspects of security are preserved.

PGP at the Receiver site (B)



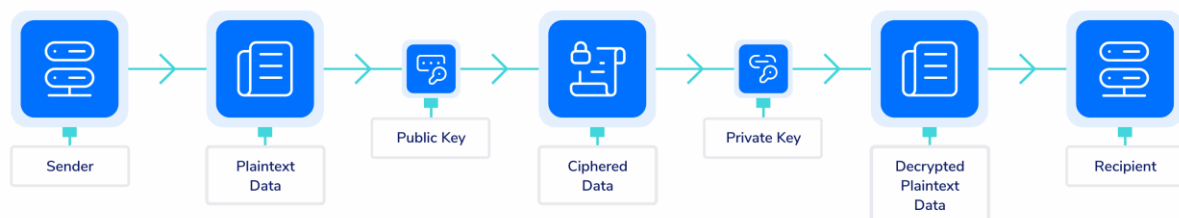
Disadvantages of PGP Encryption

- **The Administration is difficult:** The different versions of PGP complicate the administration.
- **Compatibility issues:** Both the sender and the receiver must have compatible versions of PGP. For example, if you encrypt an email by using PGP with one of the encryption techniques, the receiver has a different version of PGP which cannot read the data.
- **Complexity:** PGP is a complex technique. Other security schemes use symmetric encryption that uses one key or asymmetric encryption that uses two different keys. PGP uses a hybrid approach that implements symmetric encryption with two keys. PGP is more complex, and it is less familiar than the traditional symmetric or asymmetric methods.
- **No Recovery:** Computer administrators face the problems of losing their passwords. In such situations, an administrator should use a special program to retrieve passwords. For example, a technician has physical access to a PC which can be used to retrieve a password. However, PGP does not offer such a special program for recovery; encryption methods are very strong so, it does not retrieve the forgotten passwords results in lost messages or lost files.

6. S/MIME

S/MIME or Secure/Multipurpose Internet Mail Extension is a technology widely used by corporations that enhances **email security** by providing **encryption**, which protects the content of email messages from unwanted access. It also adds digital signatures, which confirm that you are the authentic sender of the message, making it a powerful weapon against many email-based attacks.

In a nutshell, S/MIME is a commonly-used protocol for sending encrypted and digitally-signed email messages and is implemented using **S/MIME certificates**.



S/MIME Uses

S/MIME can be used to:

- Check that the email you sent has not been tampered with by a third party.
- Create digital signatures to use when signing emails.
- Encrypt all emails.
- Check the email client you're using.

How Does S/MIME Work?

To operate, S/MIME employs mathematically related public and private keys. This technology is based on asymmetric cryptography. Because the two keys are mathematically related, a message that was encrypted with the public key (which is, of course, published) can only be decrypted using the private key (which is kept secret).

When someone clicks “send” on an email, S/MIME sending agent software encrypts the message with the recipient’s public key, and the receiving agent decrypts it with the recipient’s private key. Needless to say, both the sender and the recipient must support S/MIME.

The email message decryption process can only be done with the private key associated with it, which is supposed to be in sole possession of the recipient. Unless the private key is compromised, users can be confident that only the intended recipient will have access to the confidential information contained in their emails.

Simply put, S/MIME encryption muddles emails so that they can only be viewed by receivers who have a private key to decrypt them. It prevents others, particularly malicious actors, from intercepting and reading email messages as they are sent from senders to recipients.

You may be aware that SMTP-based Internet email does not provide message security. An SMTP (Simple Mail Transfer Protocol) internet email message can be read by anyone who sees it as it travels or views it where it is stored. S/MIME uses encryption to tackle these issues.

Message encryption provides two distinct security benefits:

Confidentiality

The purpose of message encryption is to keep the contents of an email message safe. The contents are only visible to the intended recipient, and they remain private and inaccessible to anyone else who might obtain or view the message. Encryption ensures message confidentiality while in transit and storage.

Data integrity

Message encryption, like digital signatures, offers **data integrity** services as a result of the operations that make encryption possible.

As I mentioned before, S/MIME also adds a digital signature to an email. This guarantees that the sender has permission to send emails from a specific domain.

S/MIME Digital Signatures

Digital signatures are the most commonly used service of S/MIME. As the name indicates, they are the digital equivalent of the conventional, legal signature on a paper document. S/MIME digital signatures protect against **email spoofing** attempts by confirming the sender's identity, making sure that the message content has not been tampered with, and verifying that the sender actually sent the email message.

Security capabilities offered by digital signatures:

Authentication

A signature validates the answer to the question “who are you?” by allowing that entity to be distinguished from all others and proving its uniqueness. Authentication ensures that a message was sent by the individual or organization claiming to have sent it. This reduces the likelihood of email spoofing, which is common in phishing scams.

Nonrepudiation

A signature's uniqueness prevents the sender from denying that they sent the message. This is useful for purchases and transactions, legal documentation, and criminal investigations, among other things.

Data integrity

When the receiver of a digitally signed email validates the digital signature, the recipient is assured that the received email message is the same one that was signed and sent and that has not been tampered with while it traveled.

What Is a S/MIME Certificate and How Does It Work?

An email signing certificate, which you can obtain from a certificate authority, is required to sign and encrypt your email. This certificate can be used to digitally sign your emails. Once you purchase it, it will automatically get added to your email.

All senders and receivers must have a digital certificate that binds their identity to a public key. Typically, an administrator is in charge of configuring S/MIME and issuing digital certificates.

Why Need a S/MIME Certificate?

- S/MIME certificates ensure that the emails you send are only accessible by the intended recipient.
- They employ asymmetric encryption.
- Public and private keys will be used to encrypt and decrypt emails, ensuring that the emails you send cannot be read by anyone other than the receiving party.
- S/MIME certificates protect emails by preventing hackers from accessing or changing their contents.
- Offer both digital signatures and encryption.
- While asymmetric encryption keeps your data private, digital signatures provide authentication and message integrity.
- S/MIME certificates are installed on email clients.

How to Send a S/MIME Encrypted Mail

Gmail

When a user composes a message in Gmail, a lock icon shows up next to each receiver who has S/MIME configured. If the user intends to send the email to more than one recipient, and each of those recipients supports a distinct level of encryption, Gmail will use the lowest level of encryption supported by all recipients.

Outlook

When writing a single message in Outlook, users can choose “Encrypt with S/MIME” from the Options menu. To digitally sign or encrypt every email by default, users can select encryption, sign, or both from the Settings menu.

=====